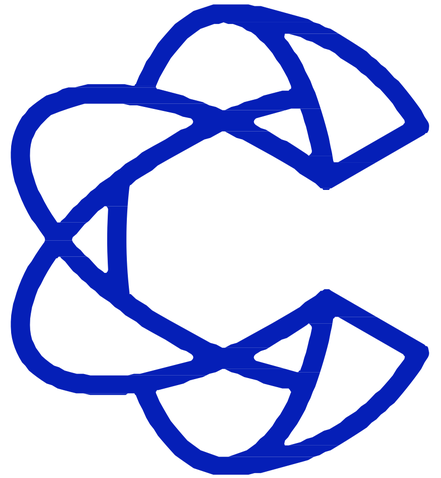
ギャップに要注意：
Windowsイベントログの見落としを検出する
（そして修正する!）

田中ザック/高橋福助



CODE BLUE2025
BECAUSE SECURITY MATTERS

アジェンダ

- イベントログ解析の重要性
- イベントログ基礎知識
- イベントログデフォルト設定の課題
- イベントログ設定の改善
- ツールによるイベントログ設定の改善
- (WELA/EventLog-Baseline-Guide)
- まとめ

自己紹介



田中ザック:

大和セキュリティコミュニティの創設者。Hayabusaを始めとする大和セキュリティOSSプロジェクトのリーダー。



高橋福助:

NTTDATA-CERT（NTTデータグループのCSIRT）で勤務。大和セキュリティOSSの開発者の一人。

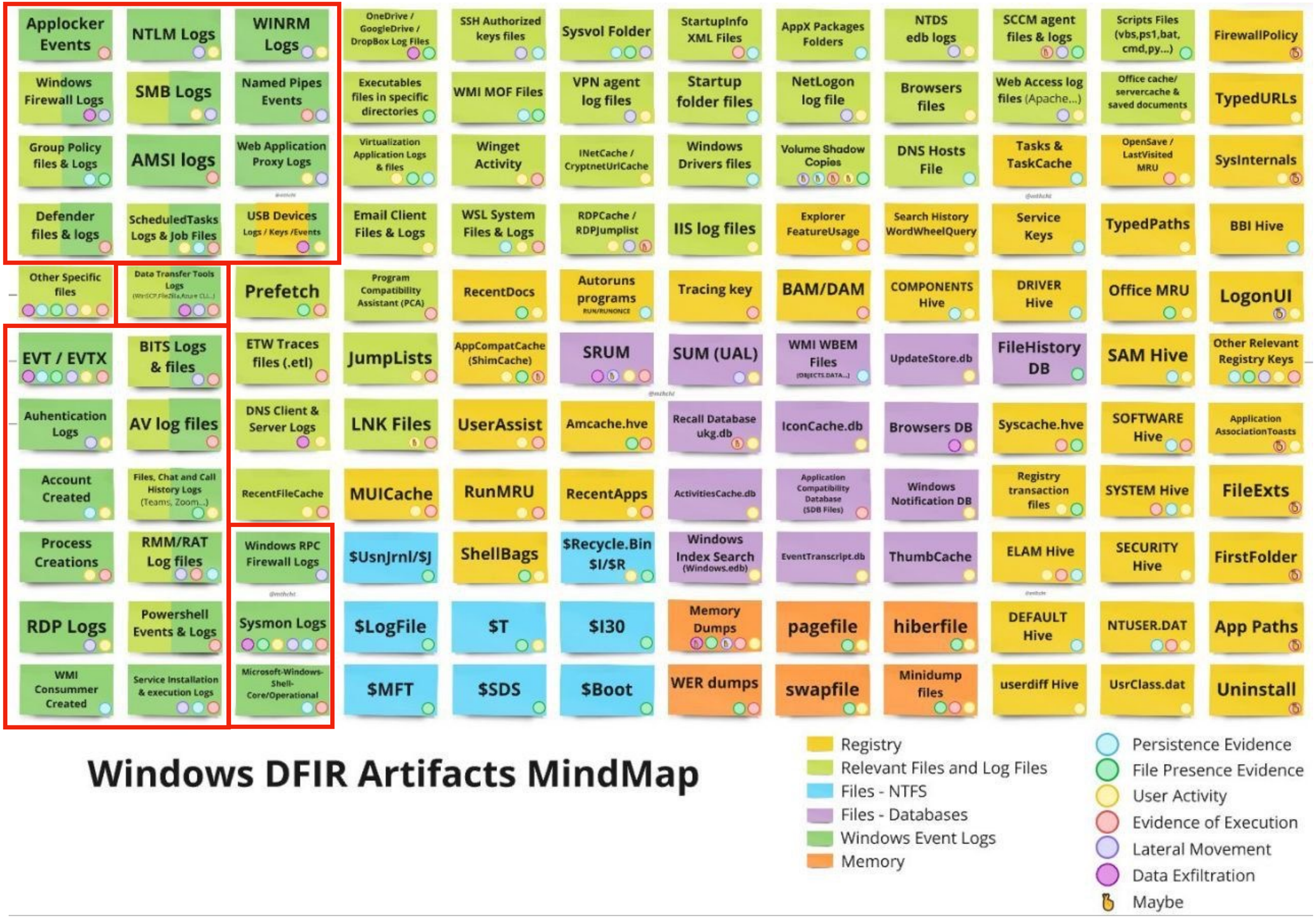
アジェンダ

- イベントログ解析の重要性
- イベントログ基礎知識
- イベントログデフォルト設定の課題
- イベントログ設定の改善
- ツールによるイベントログ設定の改善
- (WELA/EventLog-Baseline-Guide)
- まとめ

イベントログ解析の重要性

Windowsイベントログ解析の重要性

- どのWindows端末にも入っているので、
  Windowsのフォレンジック調査の基本の一部になる。
- ログ設定を事前準備で正しく改善したら多くのEDRほど詳細な証拠が残る。
- かなり"くせがある"ので、最初はとても分かりにくい。
- インシデント対応の準備段階でWindowsイベントログを迅速に解析できるように時間をかけてトレーニングしないといけない。
- レッドチーム/ペネトレーションテスターにも重要！


Applocker Events
NTLM Logs
WINRM Logs
Windows Firewall Logs
SMB Logs
Named Pipes Events
Group Policy files & Logs
AMSI logs
Web Application Proxy Logs
Defender files & logs
ScheduledTasks Logs & Job Files
USB Devices Logs / Keys /Events
OneDrive / GoogleDrive / DropBox Log Files
SSH Authorized keys files
Sysvol Folder
StartupInfo XML Files
AppX Packages Folders
NTDS edb logs
SCCM agent files & logs
Scripts Files (vbs,ps1,bat, cmd,py...)
FirewallPolicy
Executables files in specific directories
WMI MOF Files
VPN agent log files
Startup folder files
NetLogon log file
Browsers files
Web Access log files (Apache...)
Office cache/ servercache & saved documents
TypedURLs
Virtualization Application Logs & files
Winget Activity
INetCache / CryptnetUrlCache
Windows Drivers files
Volume Shadow Copies
DNS Hosts File
Tasks & TaskCache
OpenSave / LastVisited MRU
SysInternals
Email Client Files & Logs
WSL System Files & Logs
RDPCache / RDPJumplist
IIS log files
Explorer FeatureUsage
Search History WordWheelQuery
Service Keys
TypedPaths
BBI Hive
Other Specific files
Data Transfer Tools Logs
Prefetch
Program Compatibility Assistant (PCA)
RecentDocs
Autoruns programs
Tracing key
BAM/DAM
COMPONENTS Hive
DRIVER Hive
Office MRU
LogonUI
EVT / EVTX
BITS Logs & files
ETW Traces files (.etl)
JumpLists
AppCompatCache (ShimCache)
SRUM
SUM (UAL)
WMI WBEM Files
UpdateStore.db
FileHistory DB
SAM Hive
Other Relevant Registry Keys
Auhentication Logs
AV log files
DNS Client & Server Logs
LNK Files
UserAssist
Amcache.hve
Recall Database ukg.db
IconCache.db
Browsers DB
Syscache.hve
SOFTWARE Hive
Application AssociationToasts
Account Created
Files, Chat and Call History Logs (Teams, Zoom...)
RecentFileCache
MUICache
RunMRU
RecentApps
ActivitiesCache.db
Application Compatibility Database (SDB Files)
Windows Notification DB
Registry transaction files
SYSTEM Hive
FileExts
Process Creations
RMM/RAT Log files
Windows RPC Firewall Logs
$UsnJrnl/$J
ShellBags
$Recycle.Bin $I/$R
Windows Index Search (Windows.edb)
EventTranscript.db
ThumbCache
ELAM Hive
SECURITY Hive
FirstFolder
RDP Logs
Powershell Events & Logs
Sysmon Logs
$LogFile
$T
$I30
Memory Dumps
pagefile
hiberfile
DEFAULT Hive
NTUSER.DAT
App Paths
WMI Consummer Created
Service Installation & execution Logs
Microsoft-Windows-Shell-Core/Operational
$MFT
$SDS
$Boot
WER dumps
swapfile
Minidump files
userdiff Hive
UsrClass.dat
Uninstall
Windows DFIR Artifacts MindMap
Registry
Relevant Files and Log Files
Files - NTFS
Files - Databases
Windows Event Logs
Memory
Persistence Evidence
File Presence Evidence
User Activity
Evidence of Execution
Lateral Movement
Data Exfiltration
Maybe

イベントログの基礎知識

Windowsイベントログの基本知識

- Windows XP/2003: .evt
  パフォーマンスが悪かったため、無効にされることが多かった。
  ログ転送もできなかった。
- Windows Vista以降：.evtx
- .evtxはマイクロソフトの独自バイナリフォーマットのXMLファイル
- C:¥Windows¥System32¥winevt¥Logs配下にあるが、VSS、未使用領域、そしてメモリからある程度のログを抽出することも可能。

Windowsイベントログの基本知識

- <Event>タグ配下に2つのセクションで構成されている：
  <System>(前半)と<EventData>または<UserData>(後半)
- パターン１：　　パターン２：
  <Event>　　<Event>
  <System>　　<System>
  <EventData>　　<UserData>
- <System>配下のフィールドは固定で共通のデータがある
- 残念ながら<EventData>または<UserData>はの中身は
  イベントによってフィールドが完全に変わってくる・・
- イベントビューアーでは、XMLデータを元にレンダーされたメッセージがある

イベントの見本(前半の<System>)

```
- <Event xmlns="http://schemas.microsoft.com/win/2004/08/events/event">
  - <System>
      <Provider Name="Microsoft-Windows-Security-Auditing" Guid="{54849625-5478-4994-A5BA-3E3B0328C30D}" />
      <EventID>4625</EventID>
      <Version>0</Version>
      <Level>0</Level>
      <Task>12544</Task>
      <Opcode>0</Opcode>
      <Keywords>0x8010000000000000</Keywords>
      <TimeCreated SystemTime="2021-06-18T14:44:08.454527200Z" />
      <EventRecordID>2650</EventRecordID>
      <Correlation ActivityID="{1F064E34-5A91-0001-DE4E-061F915AD701}" />
      <Execution ProcessID="596" ThreadID="648" />
      <Channel>Security</Channel>
      <Computer>pc-dk.hinokabegakure-no-sato.local</Computer>
      <Security />
    </System>
```

```
- <EventData>
    <Data Name="SubjectUserSid">S-1-5-21-2227440290-791489279-1031732972-1117</Data>
    <Data Name="SubjectUserName">d-kato</Data>
    <Data Name="SubjectDomainName">hns</Data>
    <Data Name="SubjectLogonId">0x21ec05</Data>
    <Data Name="TargetUserSid">S-1-0-0</Data>
    <Data Name="TargetUserName">administrator</Data>
    <Data Name="TargetDomainName">PC-DK</Data>
    <Data Name="Status">0xc000006d</Data>
    <Data Name="FailureReason">%%2313</Data>
    <Data Name="SubStatus">0xc000006a</Data>
    <Data Name="LogonType">2</Data>
    <Data Name="LogonProcessName">seclogo</Data>
    <Data Name="AuthenticationPackageName">Negotiate</Data>
    <Data Name="WorkstationName">PC-DK</Data>
    <Data Name="TransmittedServices">-</Data>
    <Data Name="LmPackageName">-</Data>
    <Data Name="KeyLength">0</Data>
    <Data Name="ProcessId">0x3e8</Data>
    <Data Name="ProcessName">C:\Windows\System32\svchost.exe</Data>
    <Data Name="IpAddress">::1</Data>
    <Data Name="IpPort">0</Data>
  </EventData>
</Event>
```

- データが単純なキーバリューペア
- ログのよってフィールドが変わってくる
- フィールド名も変わってくる
- 人間が読めない16進数や
  %%2313コードが使用されている

レンダーされたメッセージ(例: 4624)

```
An account was successfully logged on.

Subject:
   Security ID:    SYSTEM
   Account Name:     PC$
   Account Domain:   DOMAIN
   Logon ID:    0x3E7

Logon Information:
   Logon Type:     5
   Restricted Admin Mode:  -
   Remote Credential Guard:  -
   Virtual Account:    No
   Elevated Token:  Yes

Impersonation Level:    Impersonation

New Logon:
   Security ID:    SYSTEM
   Account Name:     SYSTEM
   Account Domain:   NT AUTHORITY
   Logon ID:    0x3E7
   Linked Logon ID:    0x0
   Network Account Name: -
   Network Account Domain: -
   Logon GUID:    {00000000-0000-0000-0000-000000000000}

Process Information:
   Process ID:    0x3a0
   Process Name:     C:\Windows\System32\services.exe

Network Information:
   Workstation Name:-
   Source Network Address: -
   Source Port:    -

Detailed Authentication Information:
   Logon Process:    Advapi
   Authentication Package: Negotiate
   Transited Services: -
   Package Name (NTLM only): -
   Key Length:    0
```

```
This event is generated when a logon session is created. It is generated on
the computer that was accessed.

The subject fields indicate the account on the local system which requested
the logon. This is most commonly a service such as the Server service, or a
local process such as Winlogon.exe or Services.exe.

The logon type field indicates the kind of logon that occurred. The most
common types are 2 (interactive) and 3 (network).

The New Logon fields indicate the account for whom the new logon was created,
i.e. the account that was logged on.

The network fields indicate where a remote logon request originated.
Workstation name is not always available and may be left blank in some cases.

The impersonation level field indicates the extent to which a process in the
logon session can impersonate.

The authentication information fields provide detailed information about this
specific logon request.
   - Logon GUID is a unique identifier that can be used to correlate this event
with a KDC event.
   - Transited services indicate which intermediate services have participated
in this logon request.
   - Package name indicates which sub-protocol was used among the NTLM
protocols.
   - Key length indicates the length of the generated session key. This will be
0 if no session key was requested.
```

<System>フィールド

フィールド名	例	重要度	説明
Provider Name	Microsoft-Windows-PowerShell	◯	イベントログの発行元
Guid	A0C1853B-5C40-4B15-8766-3CF1C58F985A	X	プロバイダのGUID
EventID	1、4624、4104、4688等々	◯	各イベントプロバイダが出す個々の出来事に固有のID。値: 0〜65535。注意: 重複することもある！
Version	0、1、2等	△	ログ形式のバージョン。新しいバージョンでは、追加のフィールドが含まれている場合がある
Level	0〜5	△	イベントの重大度。注意: DFIR観点ではない。
Task	0、7、111等	X	イベントが属する作業カテゴリ。PowerShellプロバイダの111 -> NamedPipe等の名前解決が必要。0 = 未分類。
Opcode	0、1、2、20等	X	動作の種類。12 = Connect等のプロバイダごとの名前解決が必要。0 = 未設定。
Keywords	0x0、0x8000000000000000等	X	複数のキーワード(例: Session、Pipeline)を可能にするため、64ビットのビットマスク。プロバイダごとの名前解決が必要。
TimeCreated	2021-11-18T07:43:22.705991000Z	◯	ログが記録された時間。タイムゾーンはUTC。形式はISO-8601。
EventRecordID	1〜9,223,372,036,854,775,807　(2^63)	◯	各ログ記録（レコード）を一意に識別する番号。ログがクリアされない限り、リセットされない。ギャップ=ログ改ざんの可能性
Correlation	CD4E5D70-1D10-0001-895D-4ECD101DD801等	?	関連しているイベントの識別子。定義されていない場合が多い。
Execution ProcessID	ProcessID="2148" ThreadID="3896"	X	イベントを書き込んだプロセスとスレッドID
Channel	Security、Application、System等	◯	Windows イベントの記録先／ログの入れ物。殆どの場合は、ログのファイル名と同じ。
Computer	ComputerA、DC01等	◯	コンピュータ名を表すフィールド。注意: Win11ではシステム用の異なるコンピュータ名がある場合がある
Security	UserID=“S-1-5-21-4230534742-2542757381-3142984815-1111"、UserID="S-1-5-18"等	△	イベントと関連しているユーザのSID。多くは未記録で、記録がある場合はたいていシステムプロセス。ApplicationとPowerShellログでユーザを特定できるかもしれない

レベル

値	意味	説明
0	LogAlways	常に記録
1	Critical	重大 / 致命的
2	Error	エラー
3	Warning	警告
4	Informational	情報
5	Verbose	詳細 / デバッグ

注意：DFIR観点ではないので、あまり役に立たない。
また、通常エラーが出る。詐欺に悪用するので、要注意！

<EventData>と<UserData>フィールド

- 残念ながら、フィールドはイベントごとに完全に変わってくる
- また、フィールド名の決まりがない
- 数百種類あるさまざまなフィールドを見分けられるように慣れる必要がある・・
- 重要なログを説明する時に重要なフィールドを説明する

Windowsイベントログの基本知識

- ビルトインのイベントログビューアー: Event Viewer
- C:¥Windows¥System32¥eventvwr.msc
- 簡単な確認はできるが、DFIR調査等に向いていない
- ログの確認以外に、GUIでログの設定変更も可能
  (有効・無効・最大のファイルサイズの変更等々)

Event Viewer

File Action View Help

Event Viewer (Local)
- Custom Views
- Windows Logs
- Applications and Services Logs
- Subscriptions

Event Viewer (Local)

Overview and Summary

Last refreshed: 10/1/2025 12:22:57 AM

Overview

To view events that have occurred on your computer, select the appropriate source, log or custom view node in the console tree. The Administrative Events custom view contains all the administrative events, regardless of source. An aggregate view of all the logs is shown below.

Summary of Administrative Events

Event Type	Event ID	Source	Log	Last hour	24 hours	7 days
Critical	-	-	-	0	0	0
Error	-	-	-	0	0	15
Warning	-	-	-	0	7	398
Information	-	-	-	23	75	502
Audit Success	-	-	-	106	287	1,013

Recently Viewed Nodes

Name	Description	Modified	Created
Windows Logs\Security	N/A	10/1/2025 12:22:21 AM	5/3/2022 11:30:55 PM
Windows Logs\System	N/A	10/1/2025 12:14:31 AM	5/3/2022 11:30:55 PM
Applications and Services ...	N/A	3/26/2025 3:38:32 PM	5/4/2022 3:10:37 PM
Windows Logs\Application	N/A	10/1/2025 12:19:59 AM	5/3/2022 11:30:55 PM
Windows Logs\Forwarded...	N/A		
Windows Logs\Setup	N/A	9/24/2025 10:36:45 PM	5/3/2022 11:30:55 PM

Log Summary

Log Name	Size (Curre...	Modified	Enabled	Retention Policy
Windows PowerShell	1.07 MB/1...	9/30/2025 10:35:13 PM	Enabled	Overwrite events as nece...
ThinPrint Diagnostics	68 KB/1.00...	3/26/2025 3:38:32 PM	Enabled	Overwrite events as nece...
System	1.07 MB/2...	10/1/2025 12:14:31 AM	Enabled	Overwrite events as nece...
Security	2.07 MB/2...	10/1/2025 12:22:21 AM	Enabled	Overwrite events as nece...
Key Management Service	68 KB/20 ...	3/26/2025 3:38:32 PM	Enabled	Overwrite events as nece...
Internet Explorer	68 KB/1.00...	3/26/2025 3:38:32 PM	Enabled	Overwrite events as nece...

Actions

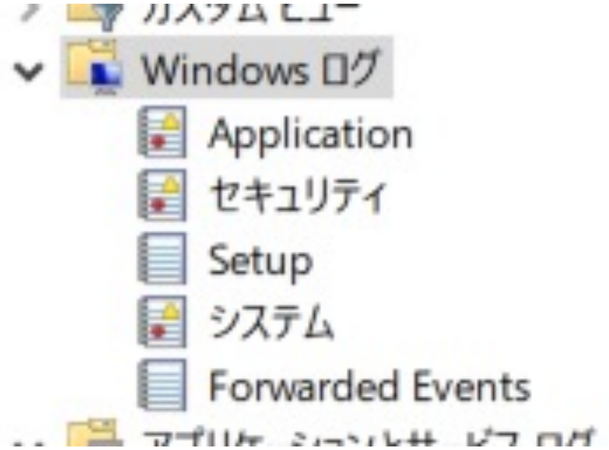
Event Viewer (Local)
- Open Saved Log...
- Create Custom View...
- Import Custom View...
- Connect to Another Computer...
- View
- Refresh
- Help

Windowsイベントログの基本知識

- 主なWindowsログ:
  - Application: アプリケーション層のログ
  - Security: アカウント管理、ログオン、オブジェクトへのアクセス等々（OSしか書き込みできない。アクセスするのにローカル管理者権限が必要。）
  - Setup: ソフトのインストール、アップデートの履歴等
  - System:ドライバ、サービスの開始・停止等
  - Forwarded Events: 転送されたログ

Windowsイベントログの基本知識

- 主なWindowsログ:Application、セキュリティ、Setup、システム

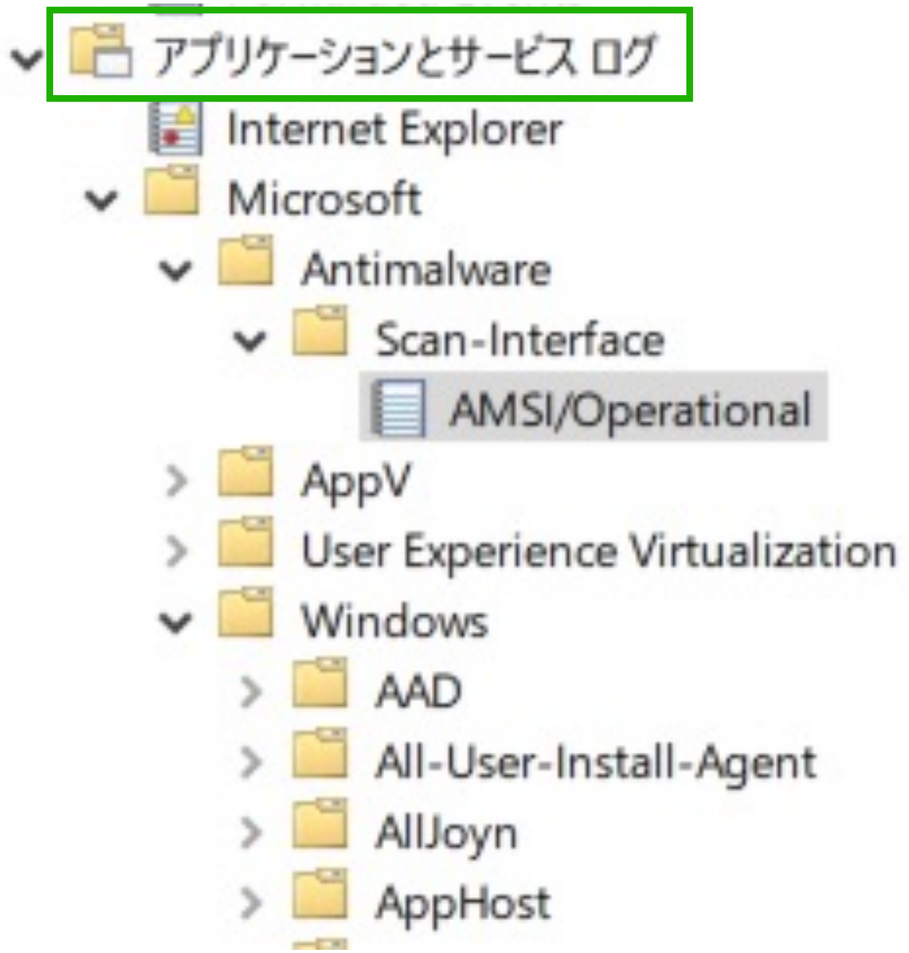


名前	種類	イベント数	サイズ
Application	管理	1,058	2.07 MB
セキュリティ	管理	2,706	2.07 MB
Setup	使用可能	3	68 KB
システム	管理	1,732	1.07 MB
Forwarded Events	使用可能	0	0 バイト

- 日本語環境での和訳が不完全な箇所がある・・
- ログオンイベント、アカウント管理、オブジェクトへのアクセス等々調査に役立つ多くのログはSecurityログに入っているので、横展開、アカウントの成りすまし、
  バックドアアカウント作成等々を調べる場合は主にSecurityイベントを調査する。
- 悪意のあるサービスの確認やシステムイベントはSystemログを確認する。

Windowsイベントログの基本知識

- 主なログ以外に325個の「アプリケーションとサービスログ」がある
- 普段何も記録されないログも多いが、重要なエビデンスが入っているログもあるので、調査する際に確認する必要がある。
  例：Windows DefenderのAMSI、Powershell等々
- Securityログほどイベント数が少ないので、ログはより長く残る

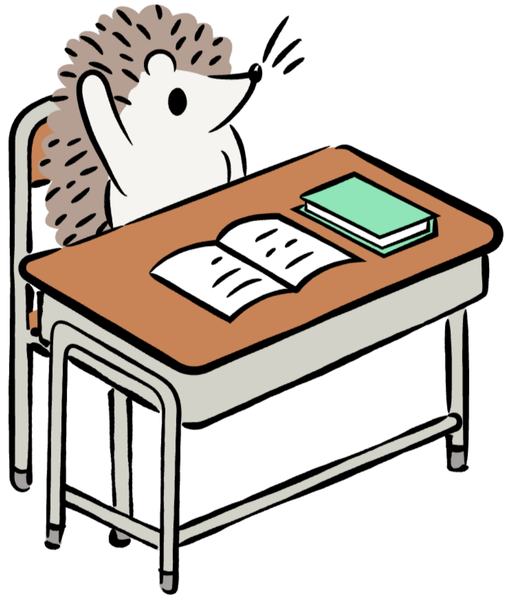


Windowsイベントログの基本知識

- 多くのログはターゲット端末で生成されるが、
  たまにはソース(通信元の)端末で生成される。
  例：TerminalServices-RDPClientログ、Security 4648 Explicit Logon
- 決まった形式が無いので、イベントIDによって内容が完全に変わってくる。そのため、本来Excel等での解析がやりにくい。

イベントログの
デフォルト設定の課題

（グループポリシー(GPO)やセキュリティベースライン等を通じて）イベントログの監査設定を設定している方いらっしゃいますか？



Windowsのデフォルトログ設定の問題

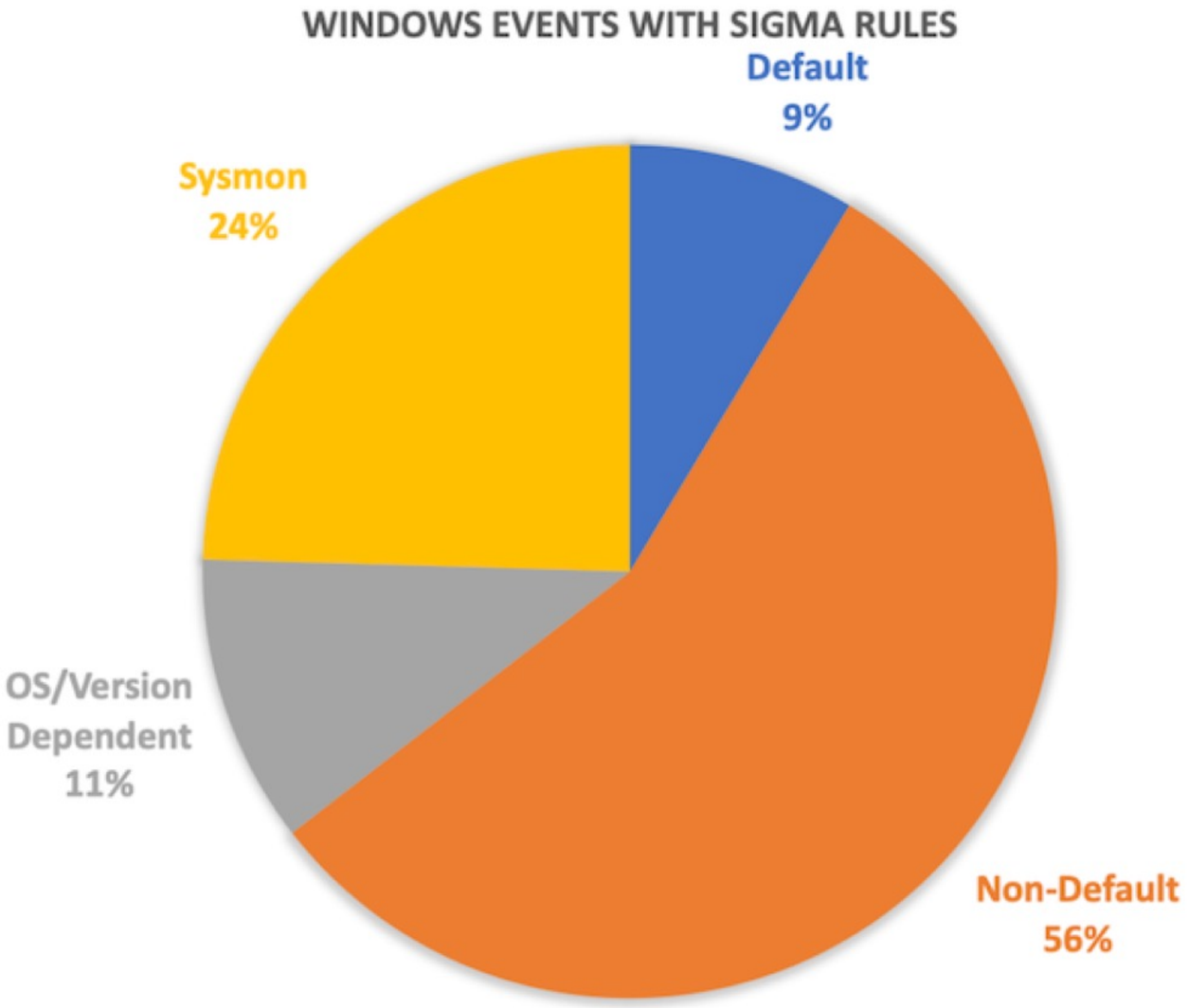
- **Windowsログのデフォルト設定は不十分！**
- デフォルトで7～9割ぐらいの調査に欲しいログが記録されない！
- デフォルトのログサイズはたった20MBなので、特にDCやサーバのログはすぐに上書きされ、証拠が無くなってしまうことが多い。
- ログオンに失敗、Powershell実行、プロセス実行等々のログが残らないので、フォレンジック調査がとても困難になる。
- GPO (グループポリシーオブジェクト)で端末のログ設定を改善した上で、マイクロソフトのsysmonツールで更にフォレンジックエビデンスを残すべき。

Sigmaルールとは？

- ログデータに対してシグネチャ（YAMLルール）を定義して攻撃を検知するための**オープン**な**業界標準フォーマット**で、**無償で利用**できる。
- ルールをそのままパースして利用するか、様々なバックエンド(例: Splunk, KQL, Elastic等々)に**変換**して利用する。(**Vender Neutral**!)

```yaml
title: 7Zip Compressing Dump Files
id: ec570e53-4c76-45a9-804d-dc3f355ff7a7
related:
    - id: 1ac14d38-3dfc-4635-92c7-e3fd1c5f5bfc
      type: derived
status: test
description: Detects execution of 7z in order to compress a file with a ".dmp"/".dump" extension,
references:
    - https://thedfirreport.com/2022/09/26/bumblebee-round-two/
author: Nasreddine Bencherchali (Nextron Systems)
date: 2022-09-27
modified: 2023-09-12
tags:
    - attack.collection
    - attack.t1560.001
logsource:
    category: process_creation
    product: windows
detection:
    selection_img:
        - Description|contains: '7-Zip'
        - Image|endswith:
              - '\7z.exe'
              - '\7zr.exe'
              - '\7za.exe'
        - OriginalFileName:
              - '7z.exe'
              - '7za.exe'
    selection_extension:
        CommandLine|contains:
            - '.dmp'
            - '.dump'
            - '.hdmp'
    condition: all of selection_*
falsepositives:
    - Legitimate use of 7z with a command line in which ".dmp" or ".dump" appears accidentally
    - Legitimate use of 7z to compress WER ".dmp" files for troubleshooting
level: medium
```

適切なDFIRに必要なログ



- Sigma検知ルールに対応しているWindowsイベントの割合。
- 既定設定のままでは、Sigmaルールのうち10～20%しか利用できない。
- すべてのWindowsログ設定を有効にすると、最大75%のルールを使用できる
- Sysmonを導入すれば、すべてのルールが活用可能。

Sigmaルールに対応するWindowsイベント

Sigma Log Source	Channel and EID	Default Settings	Rules	Percent
process_creation	Microsoft-Windows-Sysmon/Operational 1 or Security 4688	non-default	804	49.36%
security	Security	partial	139	8.53%
ps_script	Microsoft-Windows-PowerShell/Operational 4104	partial	125	7.67%
registry_set	Microsoft-Windows-Sysmon/Operational 13	sysmon	109	6.69%
file_event	Microsoft-Windows-Sysmon/Operational 11	sysmon	96	5.89%
system	System	default	50	3.07%
image_load	Microsoft-Windows-Sysmon/Operational 7	sysmon	39	2.39%
registry_event	Microsoft-Windows-Sysmon/Operational 12/13/14	sysmon	37	2.27%
ps_module	Microsoft-Windows-PowerShell/Operational 4103	non-default	30	1.84%
network_connection	Microsoft-Windows-Sysmon/Operational 3	sysmon	29	1.78%
process_access	Microsoft-Windows-Sysmon/Operational 10	sysmon	25	1.53%
pipe_created	Microsoft-Windows-Sysmon/Operational 17/18	sysmon	14	0.86%
application	Application	default	13	0.80%
dns_query	Microsoft-Windows-Sysmon/Operational 22	sysmon	12	0.74%
ps_classic_start	Windows PowerShell 400	default	10	0.61%
create_remote_thread	Microsoft-Windows-Sysmon/Operational 8	sysmon	10	0.61%

デフォルトログ設定の問題の例

- デフォルトでは4625のイベント（アカウントがログオンに失敗した）がクライアントOSでは残らない！
- また、サーバでは4776のNTLM認証失敗ログもデフォルトで残らないので、パスワード推測/スプレー攻撃等を検知できない場合がある！
- 一番重要なプロセス作成ログ(Security 4688 / Sysmon 1)はデフォルトでは記録されない！
- ローカルグループポリシーエディターでデフォルト設定を確認できる

イベントログ設定を確認する方法

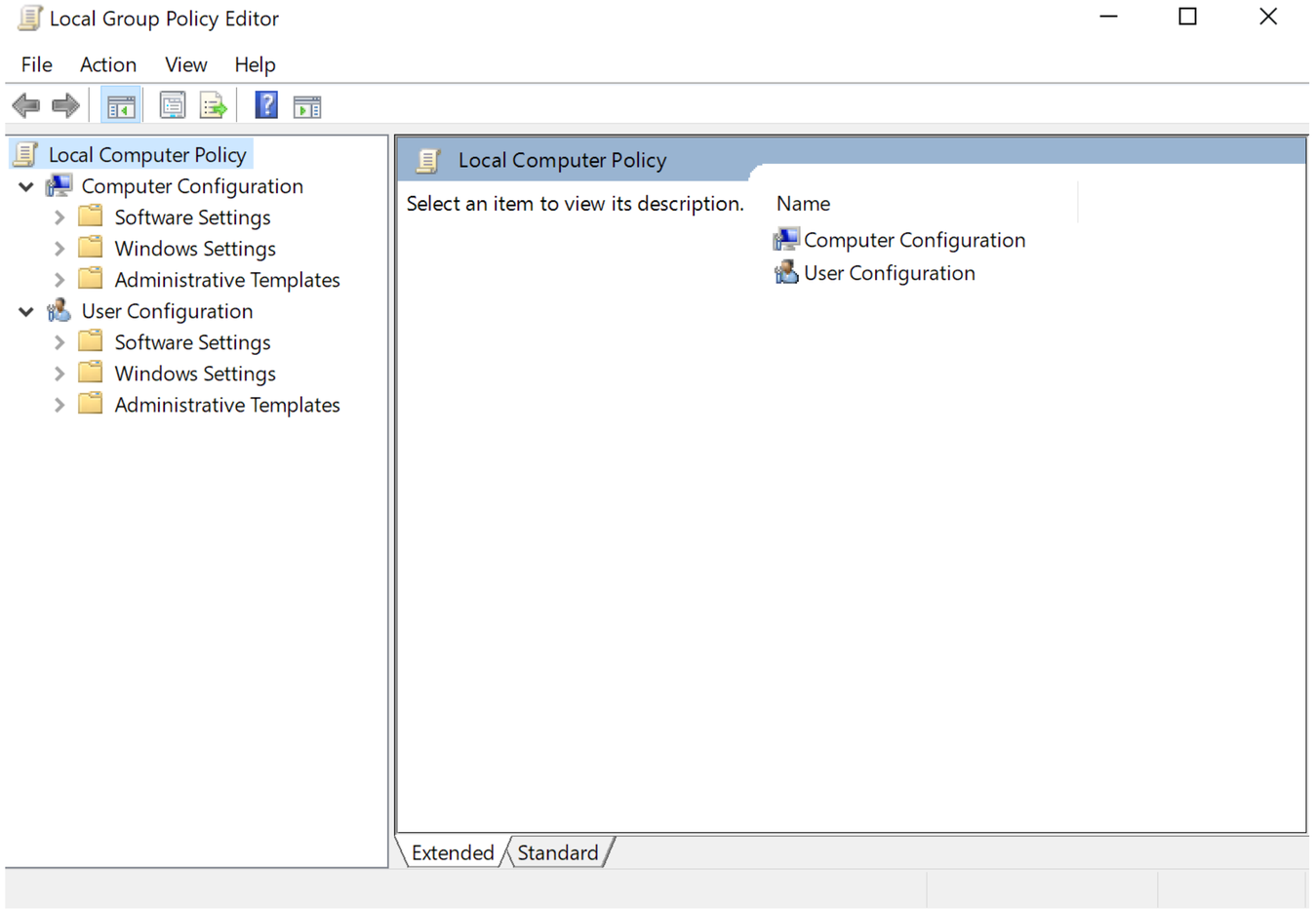
- 1台の端末・サーバ:
  - auditpol、wevtutil、regコマンド
  - ローカルグループポリシーエディタ
- 多くの端末・サーバ:
  - グループポリシー
  - InTune

auditpol/wevtutil/regの例

- SecurityログのCredential Validationサブカテゴリを有効にする:
  auditpol /set /subcategory:{0CCE923F-69AE-11D9-BED3-505054503030} /success:enable /failure:enable
- Securityログの最大サイズを1GBに増やす:
  wevtutil sl Security /ms:1073741824
- コマンドラインオプションの記録を有効にする:
  reg add HKLM¥SOFTWARE¥Microsoft¥Windows¥CurrentVersion¥Policies¥System¥Audit /v ProcessCreationIncludeCmdLine_Enabled /f /t REG_DWORD /d 1

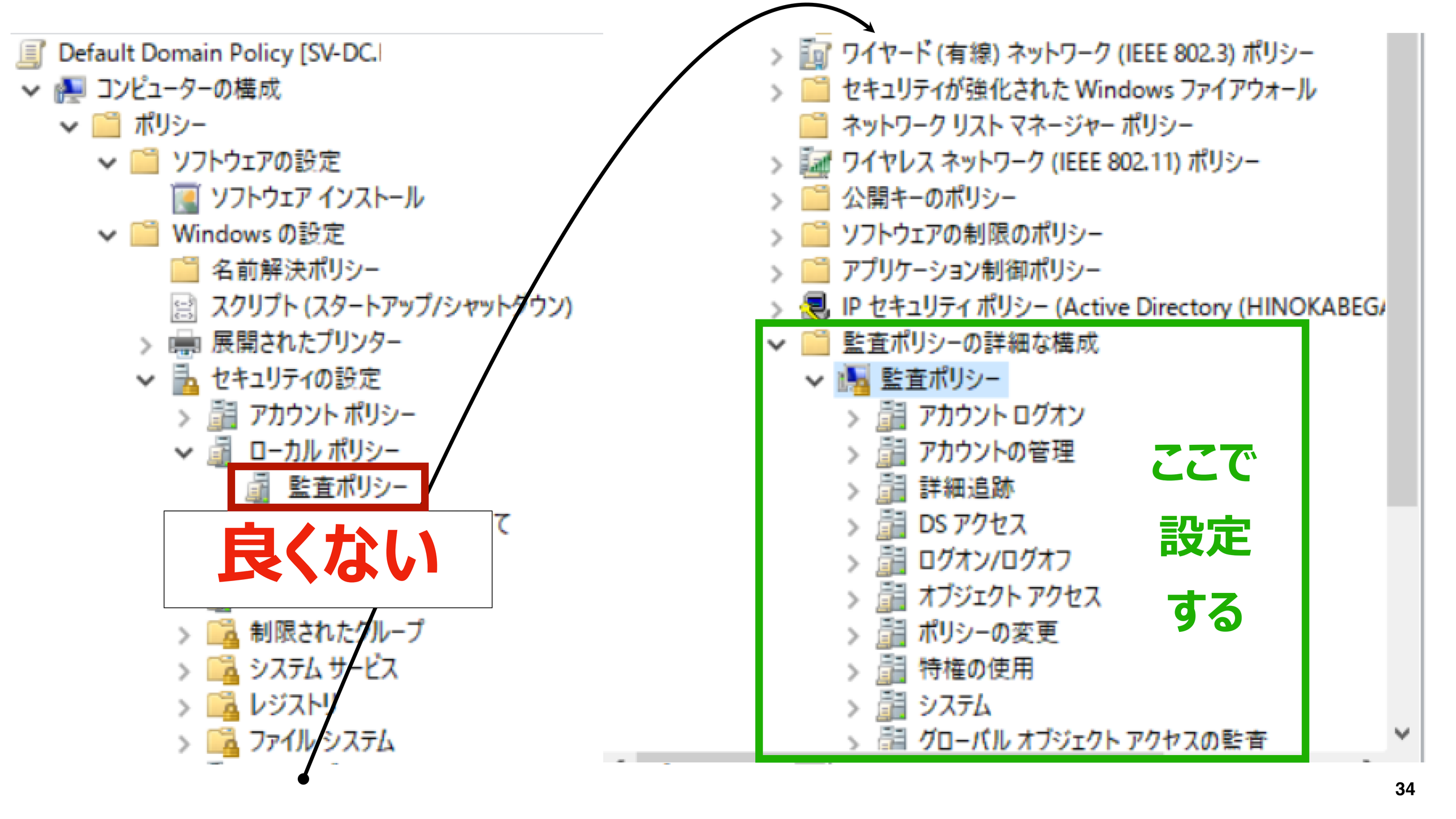
ローカルグループポリシーエディタ

- C:¥Windows¥System32¥gpedit.msc

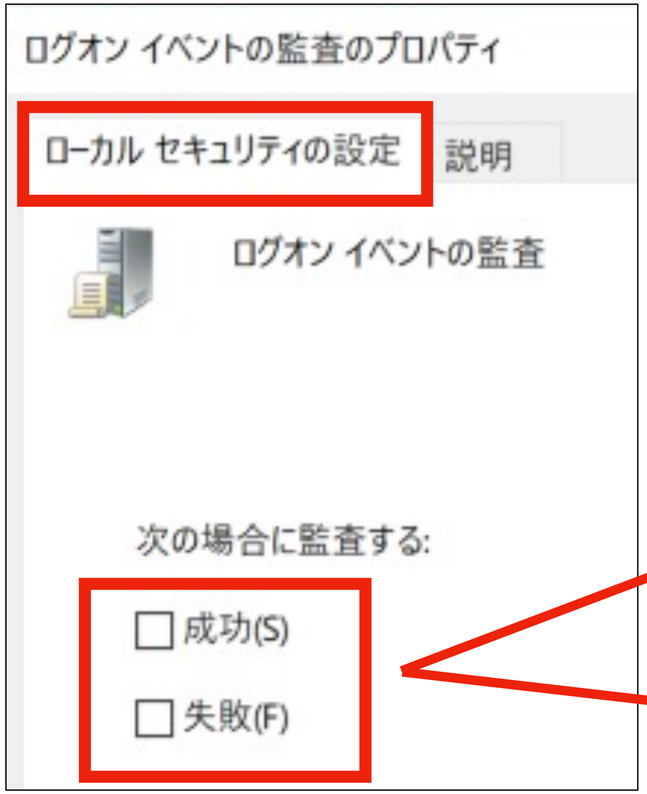


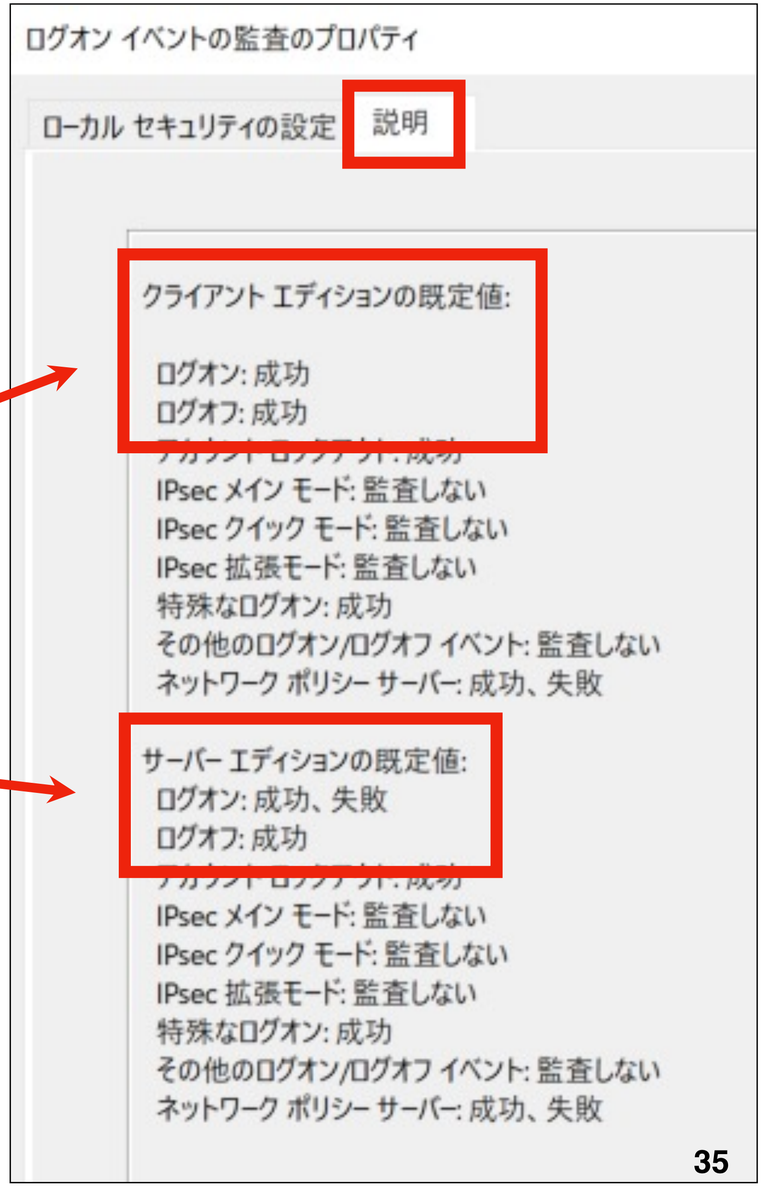
Windows GPOの注意点

- 「ベーシックな設定項目」を有効にすると、複数の不要なログが大量に生成される可能性がある上、「監査ポリシーの詳細な構成」で詳細にログ設定を変えるとベーシックな設定が無効になってしまうので、基本的に「監査ポリシーの詳細な構成」の監査ポリシーを設定すべき。


Default Domain Policy [SV-DC.
コンピューターの構成
ポリシー
ソフトウェアの設定
ソフトウェア インストール
Windows の設定
名前解決ポリシー
スクリプト (スタートアップ/シャットダウン)
展開されたプリンター
セキュリティの設定
アカウント ポリシー
ローカル ポリシー
監査ポリシー
良くない
制限されたグループ
システム サービス
レジストリ
ファイル システム
ワイヤード (有線) ネットワーク (IEEE 802.3) ポリシー
セキュリティが強化された Windows ファイアウォール
ネットワーク リスト マネージャー ポリシー
ワイヤレス ネットワーク (IEEE 802.11) ポリシー
公開キーのポリシー
ソフトウェアの制限のポリシー
アプリケーション制御ポリシー
IP セキュリティ ポリシー (Active Directory (HINOKABEGA
監査ポリシーの詳細な構成
監査ポリシー
アカウント ログオン
アカウントの管理
詳細追跡
DS アクセス
ログオン/ログオフ
オブジェクト アクセス
ポリシーの変更
特権の使用
システム
グローバル オブジェクト アクセスの監査
ここで
設定
する

デフォルトログ設定の問題の例





デフォルトではチェックが入っていないので
デフォルトの設定が使用される。
クライアントの場合は成功したログオンのみ。

デフォルトログ設定の問題（２）



- 注意：GPOの適用は複雑なので、チェックが入っていなくてもログが記録される場合があるし、逆にチェックが入っているのにログが記録されないこともある！
- 設定が終わったら、正しくログが記録されているかどうか検証する必要がある。

Windowsイベントログ設定ガイド

- Microsoft
- Australian Cyber Security Centre (ACSC)
- 大和セキュリティによる、DFIRと脅威ハンティングのためのWindowsイベントログ設定ガイド

Microsoftの監査ポリシーのおすすめ

- https://docs.microsoft.com/ja-jp/windows-server/identity/ad-ds/plan/security-best-practices/audit-policy-recommendations
- "より強力な推奨事項"をおすすめする。

Australian Cyber Security Centre (ACSC)

- https://www.cyber.gov.au/acsc/view-all-content/publications/windows-event-logging-and-forwarding

Event Category	Description	Why	Value	Noise	Implementation Notes
Sysmon	Provides visibility of process creation and termination, driver and library loads, network connections, file creation, registry changes, process injection, and more.	Detects many forms of malware execution, persistence and misuse of legitimate tools including application control bypasses. Detects process injection and some forms of credential and password hash access.	Very High	Very High	If Sysmon can't be deployed use process tracking instead.

ACSCが勧めるWindowsログ設定

- 少なとも18ヶ月のログを保管する
- クライアントとサーバGPO (Group Policy Object)を作成する
- パフォーマンスに悪影響がある可能性があるので、事前テストが必須！
- Windowsのデフォルトログは不十分なので、sysmonも導入すべき

クライアントログサイズの設定

- セキュリティログ 20MB → 1GB以上
- Powershellログ 15MB → 512MB以上
- アプリケーションとシステムログ 20MB → 128MB以上
- その他のログ(約325個中の約15個) 1MB → 64MB以上
- 可能であれば、Sysmonログ 1GB以上
- 最大: 約3.5GB (実際は最大までいかない場合が殆ど)
- HDD 256GBの場合は最大約1.5～2%！
- 少なくてもHDD容量の5%をログに割り当てるべき

サーバログサイズの設定

- セキュリティログ 20MB → 2GB以上
  ※DCの場合は4GBでも!
  ※とても古いサーバOS(2012以下)でない限り！
- Powershellログ 15MB → 1GB以上
- アプリケーションとシステムログ 20MB → 128MB以上
- その他の重要なログ(約325個中の約15個) 1MB → 64MB以上
- 最大: 約8GB
- HDD 1TBの場合は最大1%以下！

ログサイズの設定の注意点

- グループポリシー管理エディターでコンピュータの構成 | ポリシー | 管理用テンプレート | Windowsコンポーネント | イベントログサービス | (アプリケーション, システム, セキュリティ)配下の「ログファイルの最大サイズ(KB)を指定する」
- 設定する際に64KB単位が必要
- サイズ: 1MB～4GB

ログ設定の改善

- 最大ファイルサイズを増やす以外に、有効にする項目が沢山ある:
  1. Securityログの様々なサブカテゴリ
  2. PowerShellログ
  3. その他のマイナーログ:
     - DriverFrameworks-UserMode Operational
     - NTLM Operational
     - PrintService Operational
     - TaskScheduler Operational
     - WMI-Activity Operational

Security監査ログのサブカテゴリ

1.アカウントログオン
- 認証情報の確認
- Kerberos認証サービス
- Kerberosサービスチケット操作
- その他のアカウントログオンイベント

2.アカウント管理
- アプリケーショングループ管理の監査
- コンピュータアカウントの管理
- 配布グループ管理の監査
- その他のアカウント管理イベント
- セキュリティグループの管理
- ユーザーアカウントの管理

3.詳細トラッキング
- DPAPIアクティビティ
- PnP（Plug and Play）アクティビティ
- プロセス作成
- プロセス終了
- RPCイベント
- トークン権限の調整

4.DSアクセス（ドメイン コントローラーのみ）
- ディレクトリ サービス レプリケーションの詳細
- ディレクトリ サービス アクセス
- ディレクトリ サービスの変更
- ディレクトリ サービス レプリケーション

5.ログオン／ログオフ
- アカウントロックアウト
- ユーザー／デバイス クレーム
- IPsec 拡張モード
- グループ メンバーシップ
- IPsec メインモード
- IPsec クイックモード
- ログオフ
- ログオン
- ネットワーク ポリシー サーバー
- その他のログオン／ログオフ イベント
- 特殊ログオン

6.オブジェクトアクセス
- アプリケーション生成イベント
- 証明書サービス
- 詳細ファイル共有
- ファイル共有
- ファイルシステム
- フィルタリング プラットフォーム接続
- フィルタリングプラットフォームパケットの破棄
- ハンドル操作
- カーネルオブジェクト
- その他のオブジェクトアクセスイベント
- レジストリ
- リムーバブル記憶域
- SAM（セキュリティ アカウント マネージャ）
- 中央アクセス ポリシーのステージング

7.ポリシー変更
- 監査ポリシーの変更
- 認証ポリシーの変更
- 認可ポリシーの変更
- フィルタリング プラットフォーム ポリシーの変更
- MPSSVC（ルールレベル）ポリシー変更
- その他のポリシー変更イベント

8.特権の使用
- 重要でない特権の使用
- 重要な特権の使用
- その他の特権使用イベントの監査

9.システム
- IPsecドライバー
- その他のシステムイベント
- セキュリティ状態の変更
- セキュリティシステム拡張
- システム整合性

10.グローバルオブジェクトアクセス
- ファイル システム（グローバルオブジェクトアクセス監査）
- レジストリ（グローバルオブジェクトアクセス監査）

3.2 詳細トラッキング: プロセス作成

プロセス作成

注意: 非常に重要なコマンドライン情報のログを取るには、別の設定を有効にする必要があります。グループポリシーでは `コンピュータの構成 > Windowsの設定 > 管理用テンプレート > システム > プロセス作成の監査 > プロセス作成イベントにコマンドラインを含める` の手順で有効にすることが出来ます。

Sigmaルールの約半分は、コマンドラインオプションを有効にしたプロセス作成に依存しています。Sysmonをインストールし、プロセス作成を監視するように設定していない場合は、Securityログでプロセス作成イベントを有効にした方が良いです。

ボリューム: `高`

デフォルトの設定: `監査なし`

推奨設定: Sysmonがインストールされていない場合は `成功と失敗`

イベントID	タイトル	Sigmaルール数	Hayabusaルールの有無	レベル	備考欄
4688	プロセス作成	902	あり	Info~Crit	
4696	プライマリトークンがプロセスに割り当てされた	0	なし	Info	Win 7/2008 R2 からこのイベントは非推奨になっている。そのため、Vista/2008 でのみ生成される。

3.2 詳細トラッキング: プロセス作成

- 注意: コマンドラインオプションも記録しないと、
  誤検知(過検知も検知漏れも）がとても多くなる！
- 例: どちらのプロセスが不審？
  1. cmd.exe
  2. cmd.exe /c "schtasks /create /tn UpdateJob /tr 'C:¥Windows¥system32¥cmd.exe /c C:¥Windows¥Temp¥updater.exe' /sc once /st 23:59”

3.2 詳細トラッキング: プロセス作成

- 問題: パスワード等の機微情報がコマンドラインに使用された場合は、記録されてしまうので、MSはデフォルトでコマンドラインの記録を無効にしている
- しかし、それは管理者/開発者の運用ミス！
- 記録されていなくても、パスワード等をコマンドラインに入れてはいけない！
- *NIXの世界では普通！
- むしろ、この運用ミスを特定するために記録して、機微情報が入っていないか定期的に確認すると良い
- 攻撃検知するのに、大事な情報なので、有効にすべき！

3.2 詳細トラッキング: プロセス作成

- コマンドラインを記録する方法:
  1. グループポリシー:
     コンピューターの構成 → ポリシー → 管理用テンプレート → システム → プロセスの作成の監査
  2. レジストリ:
     reg add "HKLM¥SOFTWARE¥Microsoft¥Windows¥CurrentVersion¥Policies¥System¥Audit" /v ProcessCreationIncludeCmdLine_Enabled /t REG_DWORD /d 1 /f

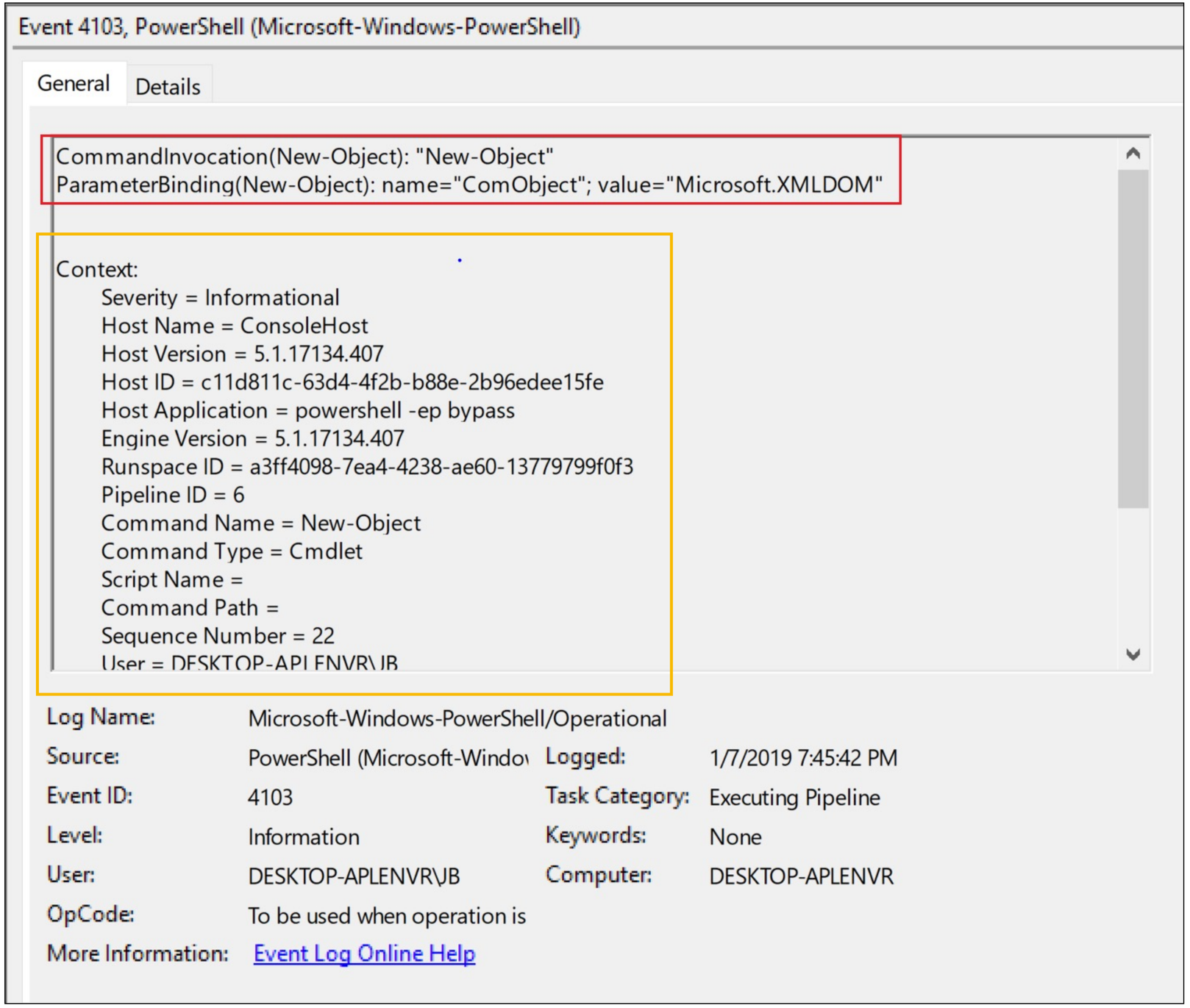
Powershell：ログ設定

- 検知：マルウェア検知、横展開等。価値:低～高。ノイズ:低～高。
- Powershell 2.0以下では以下のログ出力を設定できない。
- コンピュータの構成 | ポリシー | 管理用テンプレート | Windowsコンポーネント | Windows Powershell で以下の設定を行う：
  - 4104: スクリプトブロックログ
  - 4105,4106: ブロック開始・停止
  - 4103: モジュールログ
  - トランスクリプション(端末にテキストファイルに保存される）
- Powershell 1.0+はEngine/Providerの「Classic Log」を記録する

モジュールログ

- デバッグ用のログなので、有効にした方が良いのかは専門家によって意見が変わってくる。
- 「モジュールログ」を有効にしたい場合は、モジュール名を「＊」に設定する。
- ※Powershell 3.0+(Win7+)に対応しているので、古いOSが使用されている場合は有効にした方が良い。
- 必要以上に詳細なログが記録されるので、証拠が沢山残るが、
  ノイズも多い可能性が高い。
  例：Mimikatzの実行は約7MBで2000個以上のログが生成される。
- 実行されたPowershellコマンドと出力の両方が記録される。

- イベント4103の例


Event 4103, PowerShell (Microsoft-Windows-PowerShell)
General
Details
CommandInvocation(New-Object): "New-Object"
ParameterBinding(New-Object): name="ComObject"; value="Microsoft.XMLDOM"
Context:
Severity = Informational
Host Name = ConsoleHost
Host Version = 5.1.17134.407
Host ID = c11d811c-63d4-4f2b-b88e-2b96edee15fe
Host Application = powershell -ep bypass
Engine Version = 5.1.17134.407
Runspace ID = a3ff4098-7ea4-4238-ae60-13779799f0f3
Pipeline ID = 6
Command Name = New-Object
Command Type = Cmdlet
Script Name =
Command Path =
Sequence Number = 22
User = DESKTOP-APLENVR\JB
Log Name: Microsoft-Windows-PowerShell/Operational
Source: PowerShell (Microsoft-Windo
Logged: 1/7/2019 7:45:42 PM
Event ID: 4103
Task Category: Executing Pipeline
Level: Information
Keywords: None
User: DESKTOP-APLENVR\JB
Computer: DESKTOP-APLENVR
OpCode: To be used when operation is
More Information: Event Log Online Help

スクリプトブロックログ

- 「Powershellスクリプトブロックのログ記録を有効にする」を有効にして、「スクリプトブロックの呼び出し開始/停止イベントをログに記録する」オプションにチェックを外す。
  - ※開始/停止オプションを有効にすると数万個の不要なログ(4105、4106)が生成される可能性がある。
- ※Powershell 5.0+が必要
  - アップグレードしたらWin7+に対応しているが、デフォルトではWindows 10+に対応している。
- Powershellログの中にイベントID 4104が記録される。

スクリプトブロックログ

- (最大32KBの)ブロックごとに実行されたコマンドを記録する。
  超えた場合は、ログが沢山のログに分割されてしまう。
- スクリプトがXOR, Base64, ROT13等で難読化されていても、
  デコードされたスクリプトも記録されるので解析がしやすくなる。
- OSにスクリプトが不審だと判断された場合は、ログ設定が有効になっていなくても、4104のログが警告レベルで記録される。
- モジュールログと違って、コマンドの出力が記録されない。
- Mimikatzが実行された場合は約100個のログ(5MB)が記録されるので、モジュールログより解析しやすい！

スクリプトブロックログ

- 個人情報や資格情報が記録されないように「保護されたイベントログ」の設定を有効にできる。
  https://docs.microsoft.com/ja-jp/powershell/module/microsoft.powershell.core/about/about_logging_windows?view=powershell-7#protected-event-logging
- 運用が大変になるため、実際に有効にしている組織は少ないでしょう・・

トランスクリプションログ

- 「PowerShellトランスクリプションを有効にする」を有効にする。
- 実行されたPowershellスクリプトと出力がデフォルトではマイドキュメントのフォルダにテキストファイルとして記録される。
- 記録されるもの：
  - コンソールに表示される入力と出力のみ
  - 基本的に「画面に見えるもの」をテキストファイルに保存
- 記録されないもの：
  - 画面出力を抑制したコマンド（Out-Null, $null =, | Out-Null）
  - バックグラウンドで実行されるコード
  - スクリプト内部の処理
  - 変数への代入のみの操作
- 注意：攻撃者がログを簡単に削除できる、また、端末でログがずっと溜まっていくので、書き込み専用の共有フォルダに書き込むのが理想。
  ※常にネットワークアクセスが必要という課題がある。

PowerShellのおすすめの設定

- 端末で3種類のログを記録するのが一番情報が残るが、モジュールログが大きいため、トランスクリプションログがあれば、無効のままにすべき。
- トランスクリプションログのサイズも大きすぎる場合は、少なくてもスクリプトブロックログを記録した方が良い。
- どうしてもPowerShell 3～4を使用しないといけない場合は
  モジュールログを記録するしかない。
- SIEMに警告レベルの4104(スクリプトブロックログ）を転送する。
- PowerShellのログサイズを1GB以上にする。
- WinRM(リモートPowerShell)のログを128MB以上にする。

その他のログ

- DNS Client Events - Operational
- DHCP Clientログ
- NTLM
- PrintService - Operational
- TaskScheduler - Operational
- WMI
- 高度: Autoruns to WinEventLog

DNS Client Events - Operational

- マルウェアはよくC2サーバ等の名前解決を行うので、DNSサーバ、ネットワーク監視等でもDNSを監視すべきだが、ホストでも行うべき。
- 注意点: プログラムがWindows API経由ではなく、直接DNSリクエストを送信している場合は記録されない可能性がある。

DHCPクライアントログ

- Dhcp-Client - Operational
- DHCPv6-Client - Operational
- クライント端末は被害を受けた時にどのIPアドレスを使用していたのか把握すべき。
- DHCPサーバログでも調べられるが、イベントログで調べた方が容易な場合が多い。
- DHCP中間者攻撃の検知もできる。

NTLM

- 検知：横展開、パスワード推測攻撃等。価値:低。ノイズ:中
- Security 4776等のNTLM認証ログはあるが、上書きされる可能性があるので、こちらも有効にした方が良い。特にNTLM認証を減らすためにNTLM認証を行っている端末を特定するのに役立つ。
- ※ログ自体は既に有効になっているが、以下のグループポリシーも有効にしないと、記録されない。
- コンピュータの構成 | ポリシー | Windowsの設定 | セキュリティの設定 | ローカルポリシー | セキュリティオプション | ネットワークセキュリティ: NTLMを制限する:リモートサーバーに対する送信NTLMトラフィック → すべて監査する

PrintService - Operational

- Operationalログに印刷したファイルのファイル名が記録されるので、プライバシーの問題を避けるために、MSはデフォルトでAdminログを有効にしていたが、Operationalログを無効にしていた。
- しかし、印刷スプーラーに様々な脆弱性（例：PrinterBug、PrintNightmare等々)が発見されていて、攻撃を検知するためにOperationalログが必要。
- 社員がドキュメントを印刷して、情報を持ち出しているか確認するためにも有効にした方が良いかもしれない。
- ※最近のWindowsではOperationalログも有効になっているが確認すべき。

TaskScheduler - Operational

- 攻撃者はマルウェアの永続化またはリモートコマンド実行(横展開)のためにタスクを悪用する
- Securityログにもタスク作成等のログは記録されるが、Securityログがより頻繁に上書きされる上、TaskSchedulerログの方が良い情報が残るので、こちらも有効にすべき。

WMI

- 検知：リモートコード実行、マルウェアの起動、永続化等。
- Windows 10 v1607 (2016年8月)以降ではデフォルトでsysmonのようにWMIのログが記録される。※Sysmonログの方が情報が良い
- それ以前のOSでログを設定したい場合は、Powershellスクリプトをグループポリシーや SCCM等で実行する必要がある。
  https://github.com/AustralianCyberSecurityCentre/windows_event_logging/blob/master/events/wmi_auditing/wmi_auditing.ps1
  ※GPOで直接設定できない。
- もしくは、sysmonで監視する。

大和セキュリティによる、DFIRと脅威ハンティングのためのWindowsイベントログ設定ガイド

- https://github.com/Yamato-Security/EnableWindowsLogSettings/blob/main/README-Japanese.md



ただ、、、



たくさんあるイベントログ推奨設定を

ひとつひとつ覚えていらない、設定大変…

WELA(ゑ羅)



WELA

- https://github.com/Yamato-Security/WELA
- WELA（Windows Event Log Auditor)
- リーダー: 田中ザック氏
- 開発者: 高橋福助
- 言語: Microsoft PowerShell 5.1、PwSh Core
- 現在のWindowsイベントログ設定を、各種ベースライン（Microsoft、ASD/ACSC、Yamato Security等）と比較し、どのSigmaルールが使用可能で、どのルールが使用できないかを示す。
- また、攻撃を検知するために必要なログが取得できるよう、設定を自動で構成することもできる

WELAコマンド

- audit-settings: ログ設定を確認する
- audit-filesize: ログの最大サイズを確認する
- configure: ログ設定を改善する
- update-rules: 攻撃検知ルールを更新する

WELA - 最初の実行

- ./WELA.ps1を実行すると、以下の警告が出る:

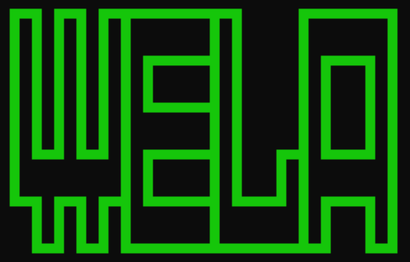
```
PS C:\tools\wela-1.0.0> .\WELA.ps1

Security warning
Run only scripts that you trust. While scripts from the internet can be useful, this script
can potentially harm your computer. If you trust this script, use the Unblock-File cmdlet to
 allow the script to run without this warning message. Do you want to run
C:\tools\wela-1.0.0\WELA.ps1?
[D] Do not run  [R] Run once  [S] Suspend  [?] Help (default is "D"):
```

- 毎回「R」を入力するのは、手間がかかるので、
  Unblock-Fileで許可すると良い

WELA - 最初の実行

```
PS C:\tools\wela-1.0.0> Unblock-File .\WELA.ps1
PS C:\tools\wela-1.0.0> .\WELA.ps1
```



```
  by Yamato Security

Invalid command. Use 'help' to see available commands.
Usage:
   ./WELA.ps1 audit-settings -Baseline YamatoSecurity     # Audit current setting and show in stdout, save to csv
   ./WELA.ps1 audit-settings -Baseline ASD -OutType gui   # Audit current setting and show in gui, save to csv
   ./WELA.ps1 audit-filesize -Baseline YamatoSecurity     # Audit current file size and show in stdout, save to csv
   ./WELA.ps1 update-rules         # Update rule config files from https://github.com/Yamato-Security/WELA
   ./WELA.ps1 help        # Show this help
```

WELA - update-rules

- 毎日GitHub ActionsでWELA.ps1が自動的にSigmaの最新のルールと同期する
- Sigmaルールは頻繁に更新されるので、まず更新すると良い

WELA - audit-settings

- ./WELA.ps1 audit-settings -Baseline YamatoSecurity -OutType guiを実行する
- 暫くすると、GUIが表示される
- ここで、各ログのデフォルト設定、現在設定、推奨設定、ボリューム、備考等々が分かる
- Sigma検知ルールをどれほど使用可能かも分かる
- 上のFilterとAdd criteria入力でフィルタを簡単に作成できる

WELA Audit Result

Filter

Add criteria

Category	SubCategory	RuleCount	RuleCountByLevel	DefaultSetting	CurrentSetting	RecommendedSetting	Volume	Note
Application		31	critical:, high:16, medium:8, low:5, info:0	Enabled	Enabled	Enabled		
Applocker		1	critical:0, high:0, medium:, low:0, info:0	Enabled	Enabled	Enabled		Enabled if AppLocker is enabled?
Bits-Client Operational		8	critical:0, high:3, medium:2, low:2, info:0	Enabled	Enabled	Enabled		
CodeIntegrity Operational		10	critical:0, high:9, medium:0, low:, info:0	Enabled	Enabled	Enabled		
Diagnosis-Scripted Operational		1	critical:0, high:, medium:0, low:0, info:0	Enabled	Enabled	Enabled		
DriverFrameworks-UserMode Operational		2	critical:0, high:0, medium:0, low:, info:0	Enabled	Enabled	Enabled		
Firewall		9	critical:0, high:2, medium:3, low:4, info:0	Enabled	Enabled	Enabled		
Microsoft-Windows-NTLM/Operational		1	critical:0, high:, medium:0, low:0, info:0	Enabled	Enabled	Enabled		This log is recommended to enable if you want to disable NTLM authentication
PowerShell	Classic	21	critical:0, high:5, medium:11, low:4, info:0	Enabled	Enabled	Enabled		
PowerShell	Module	43	critical:, high:20, medium:15, low:5, info:2	No Auditing	Disabled	Enabled	High	
PowerShell	ScriptBlock	194	critical:3, high:66, medium:100, low:24, info:0	Partially Enabled	Disabled	Enabled	High	On Win 10/2016+, if a PowerShell script is flagged as suspicious by AMSI, it will be logged with a le...
PrintService	PrintService Admin	1	critical:0, high:, medium:0, low:0, info:0	Enabled	Enabled	Enabled		
PrintService	PrintService Operational	1	critical:, high:0, medium:0, low:0, info:0	Enabled	Enabled	Enabled		
Security Advanced (Account Logon)	Credential Validation	7	critical:0, high:2, medium:4, low:0, info:0	Client OS: No Auditing | Se...	No Auditing	Client and Server OSes: Success...	Depends on...	
Security Advanced (Account Logon)	Kerberos Authentication Service	8	critical:0, high:2, medium:5, low:0, info:0	Client OS: No Auditing | Se...	No Auditing	Client OS: No Auditing | Server O...	High	
Security Advanced (Account Logon)	Kerberos Service Ticket Operations	5	critical:0, high:, medium:3, low:0, info:0	Client OS: No Auditing | Se...	No Auditing	Domain Controllers: Success and...	High	
Security Advanced (Account Management)	Computer Account Management	4	critical:0, high:, medium:, low:, info:0	Client OS: No Auditing | Se...	No Auditing	Domain Controllers: Success and...	High	
Security Advanced (Account Management)	Other Account Management Events	0	critical:0, high:0, medium:0, low:0, info:0	No Auditing	No Auditing	Success and Failure	Low	
Security Advanced (Account Management)	Security Group Management	12	critical:0, high:5, medium:2, low:5, info:0	No Auditing	Success	Success and Failure	Low	
Security Advanced (Account Management)	User Account Management	13	critical:0, high:7, medium:4, low:2, info:0	No Auditing	Success	Success and Failure	Low	
Security Advanced (Detailed Tracking)	Plug and Play Events	2	critical:0, high:0, medium:, low:, info:0	No Auditing	No Auditing	Success and Failure	Low	
Security Advanced (Detailed Tracking)	Process Creation	1,343	critical:69, high:645, medium:543, low:83, info:3	No Auditing	No Auditing	Success and Failure	High	if sysmon is not configured
Security Advanced (Detailed Tracking)	Process Termination	1	critical:0, high:, medium:0, low:0, info:0	No Auditing	No Auditing	No Auditing	High	unless you want to track the lifespan of processes
Security Advanced (Detailed Tracking)	RPC Events	0	critical:0, high:0, medium:0, low:0, info:0	No Auditing	No Auditing		High on RPC...	
Security Advanced (Detailed Tracking)	Token Right Adjusted Events	0	critical:0, high:0, medium:0, low:0, info:0	No Auditing	No Auditing			
Security Advanced (DS Access)	Directory Service Access	10	critical:2, high:5, medium:3, low:0, info:0	Client OS: No Auditing | Se...	No Auditing	Client OS: No Auditing | ADDS S...	High	
Security Advanced (DS Access)	Directory Service Changes	10	critical:0, high:6, medium:3, low:0, info:0	No Auditing	No Auditing	Client OS: No Auditing | ADDS S...	High	
Security Advanced (Logon/Logoff)	Account Lockout	17	critical:0, high:3, medium:11, low:3, info:0	Success	Success	Success and Failure	Low	
Security Advanced (Logon/Logoff)	Group Membership	0	critical:0, high:0, medium:0, low:0, info:0	No Auditing	No Auditing	No Auditing	Adds an extr...	
Security Advanced (Logon/Logoff)	Logoff	4	critical:0, high:0, medium:0, low:0, info:4	Success	Success	Success		
Security Advanced (Logon/Logoff)	Logon	55	critical:, high:9, medium:22, low:6, info:17	Client OS: Success | Server...	Success and Failure	Success and Failure	Low on client...	
Security Advanced (Logon/Logoff)	Other Logon/Logoff Events	4	critical:0, high:, medium:0, low:0, info:3	No Auditing	No Auditing	Success and Failure	Low	
Security Advanced (Logon/Logoff)	Special Logon	2	critical:0, high:0, medium:0, low:, info:0	Success	Success	Success and Failure	Low on client...	
Security Advanced (Object Access)	Certification Services	2	critical:0, high:, medium:0, low:, info:0	No Auditing	No Auditing	Success and Failure for AD CS rol...	Low to medi...	
Security Advanced (Object Access)	Detailed File Share	21	critical:, high:11, medium:8, low:0, info:0	No Auditing	No Auditing	No Auditing	Very high for...	Due to the high noise level. Enable if you can though
Security Advanced (Object Access)	File Share	3	critical:0, high:, medium:0, low:, info:0	No Auditing	No Auditing	Success and Failure	High for file s...	
Security Advanced (Object Access)	File System	24	critical:3, high:7, medium:12, low:2, info:0	No Auditing	No Auditing	Enable	Depends on...	Enable SACLs just for sensitive files
Security Advanced (Object Access)	Filtering Platform Connection	59	critical:2, high:26, medium:23, low:4, info:4	No Auditing	No Auditing	Success and Failure	High	Success and Failure if you have enough space and are not monitoring network connections with sy...
Security Advanced (Object Access)	Filtering Platform Packet Drop	0	critical:0, high:0, medium:0, low:0, info:0	No Auditing	No Auditing	Success and Failure	High	for AD CS role servers
Security Advanced (Object Access)	Kernel Object	24	critical:3, high:7, medium:12, low:2, info:0	No Auditing	No Auditing	Success and Failure	High if auditi...	Success and Failure but do not enable Audit the access of global system objects as you will generat...
Security Advanced (Object Access)	Handle Manipulation	1	critical:0, high:0, medium:, low:0, info:0	No Auditing	No Auditing	Success and Failure	High	
Security Advanced (Object Access)	Other Object Access Events	13	critical:2, high:5, medium:2, low:2, info:2	No Auditing	No Auditing	Success and Failure	Low	
Security Advanced (Object Access)	Registry	297	critical:14, high:155, medium:112, low:15, info:0	No Auditing	No Auditing	Success and Failure	Depends on...	Set SACLs for only the registry keys that you want to monitor

WELA - audit-settings

- ターミナルで以下のサマリが出る:

```
PS C:\tools\wela-1.0.0> .\WELA.ps1 audit-settings -Baseline YamatoSecurity -OutType gui
```



```
  by Yamato Security

Usable detection rules list saved to: UsableRules.csv
Unusable detection rules list saved to: UnusableRules.csv

You can utilize 23.67% of your detection rules.
```

WELA - audit-settings

- 現在、25%以下の検知ルールしか使えない！
- UsableRules.csvとUnusableRules.csvをTimeline ExplorerやExcel等で開いて、使用可能なルールと使用不可能なルールを確認できる
- インシデント対応の準備段階で、どの攻撃を検知できるか、ログ不足でどの攻撃を検知できないかを把握する必要がある！
- 検知ルールはBlackBoxではなく、オープンソースで内容を把握すべき！
  - ※そのため、プライベートルールも導入すると良い！

タイトル、レベル、サービス、カテゴリ、説明、ID

title	level	service	category	description	id
Accessing Encrypted Credentials from Google Chrome Login Databa…	medium		ps_script	Adversaries may acquire credentials from web browsers by reading file…	63c2d41b-b587-6c55-c256-9c0bb392f0a9
Powershell File and Directory Discovery	low		ps_script	Adversaries may enumerate files and directories or may search in spec…	113fcff8-c64d-8743-88b7-9ff2539cde7d
Delete Volume Shadow Copies via WMI with PowerShell - PS Script	high		ps_script	Deletes Windows Volume Shadow Copies with PowerShell code and Get-WMI…	baee41a3-2063-6125-778e-0d9710474c06
AzureHound PowerShell Commands	high		ps_script	Detects the execution of AzureHound in PowerShell, a tool to gather d…	74dda95a-b492-e2ee-4a33-b22a41a1cb57
Suspicious PowerShell Download	medium	powershell		Detects suspicious PowerShell download command	12f93a4e-cd0e-18d7-6969-b345ecc8d40a
Execution via CL_Invocation.ps1 - Powershell	high		ps_script	Detects Execution via SyncInvoke in CL_Invocation.ps1 module	6587075c-6239-f6e1-4717-4b7972b1c086
Execution via CL_Mutexverifiers.ps1	high		ps_script	Detects Execution via runAfterCancelProcess in CL_Mutexverifiers.ps1 …	f427b1c7-bbad-7bd6-bb0f-65b6170a3cb5
SyncAppvPublishingServer Execution to Bypass Powershell Restric…	medium	powershell		Detects SyncAppvPublishingServer process execution which usually util…	349e3bb4-b72b-193d-810e-7d9c145b863e
Suspicious PowerShell Invocations - Specific	high	powershell		Detects suspicious PowerShell invocation command parameters	3db961f4-6217-4957-b717-e5955c82d6e5
Suspicious PowerShell Invocations - Generic	high	powershell		Detects suspicious PowerShell invocation command parameters	391b98f2-3f42-0d06-a295-18a2aa29d39a
Suspicious Get-WmiObject	low		ps_script	The infrastructure for management data and operations that enables lo…	830423bc-69e4-b19b-5474-414e4ab0c365
Execution via CL_Invocation.ps1 (2 Lines)	high		ps_script	Detects Execution via SyncInvoke in CL_Invocation.ps1 module	13cf4134-564b-abdb-c83e-dac3ba9bac3c
Execution via CL_Mutexverifiers.ps1 (2 Lines)	high		ps_script	Detects Execution via runAfterCancelProcess in CL_Mutexverifiers.ps1 …	97408cc2-d2e8-83dd-1f84-93da08e9f191
PwSh Scriptblock	informational	powershell	ps_script	Powershell Scriptblock Logging. Windows 10+ will flag suspicious PwSh…	0f3b1343-65a5-4879-b512-9d61b0e4e3ba
Potentially Malicious PwSh	medium	powershell	ps_script	On Powershell v5+, Windows will automatically log suspicious powershe…	73be1519-4648-4ed7-b305-605504afc242
Possible CVE-2021-1675 Print Spooler Exploitation	high	printservice…		Detects events of driver load errors in print service logs that could…	5c10c39e-b9f6-d321-3598-62095b34b663
CVE-2021-1675 Print Spooler Exploitation	critical	printservice…		Detects driver load events print service operational log that are a s…	ae207e8e-3dfd-bd05-1161-e0472778f2be
Hacktool Ruler	high	security		This events that are generated when using the hacktool Ruler by Sense…	8b40829b-4556-9bec-a8ad-905688497639
Metasploit SMB Authentication	high	security		Alerts on Metasploit host's authentications on the domain.	827aa6c1-1507-3f0a-385a-ade5251bfd71
Account Tampering - Suspicious Failed Logon Reasons	medium	security		This method uses uncommon error codes on failed logons to determine s…	655eb351-553b-501f-186e-aa9af13ecf43
Potential Exploitation of CVE-2024-37085 - Suspicious ESX Admin…	high	security		Detects any creation or modification to a windows domain group with t…	2a451b93-9890-5cfe-38aa-1dc4f8f0fe0a
Operation Wocao Activity - Security	high	security		Detects activity mentioned in Operation Wocao report	c9b5cb6f-906f-3a15-b77e-1b634b1d4e55
User Added to Local Administrator Group	medium	security		Detects the addition of a new member to the local administrator group…	6695d6a2-9365-ee87-ccdd-966b0e1cdbd4
A Security-Enabled Global Group Was Deleted	low	security		Detects activity when a security-enabled global group is deleted	ae7d8d1c-f75b-d952-e84e-a7981b861590
A Member Was Removed From a Security-Enabled Global Group	low	security		Detects activity when a member is removed from a security-enabled glo…	6e0f860b-3678-7396-a4a3-7cf55f7bb01c
A Member Was Added to a Security-Enabled Global Group	low	security		Detects activity when a member is added to a security-enabled global …	26767093-828c-2f39-bdd8-d0439e87307c
Group Modification Logging	low	security		Configure systems to issue a log entry and alert when an account is a…	506379d9-8545-c010-e9a3-693119ab9261
User Added To Local Domain Admins Grp	high	security		A user was added to the local Domain Admins group.	bc58e432-959f-464d-812e-d60ce5d46fa1
User Added To Local Admin Grp	high	security		A user was added to the local Administrators group. Unfortunately the…	611e2e76-a28f-4255-812c-eb8836b2f5bb
User Added To Global Security Grp	medium	security		A user was added to a security-enabled global group. Global means the…	0db443ba-561c-4a04-b349-d74ce1c5fc8b
User Added To Global Domain Admins Grp	high	security		A user was added to the Domain Admins group. Only logged on DCs.	4bb89c86-a138-42a0-baaf-fc2f777a4506
User Added To Non-Admin Global Grp	low	security		User Added To Non-Admin Global Security Group. Only logged on DCs.	2f04e44e-1c79-4343-b4ab-ba670ee10aa0

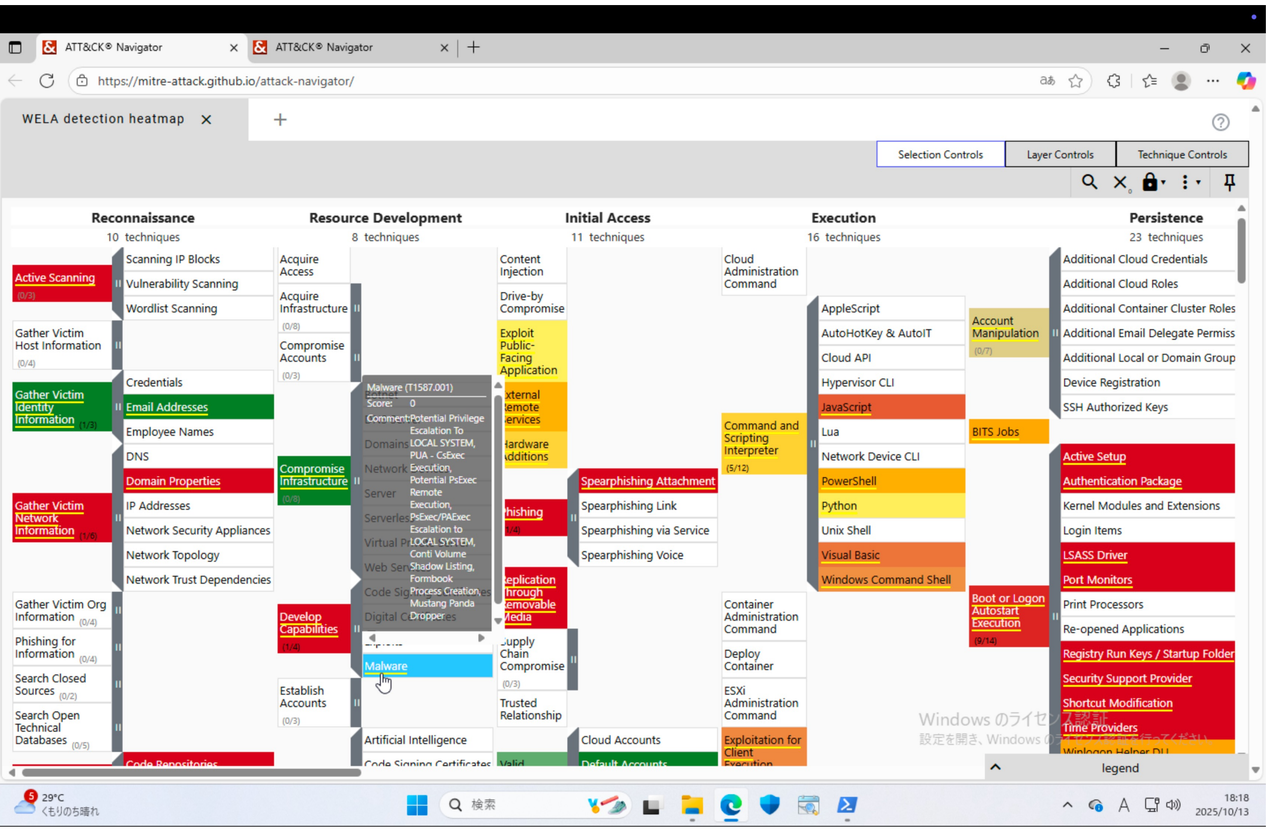
WELA - audit-filesize

- ./WELA.ps1 audit-filesize -Baseline YamatoSecurity

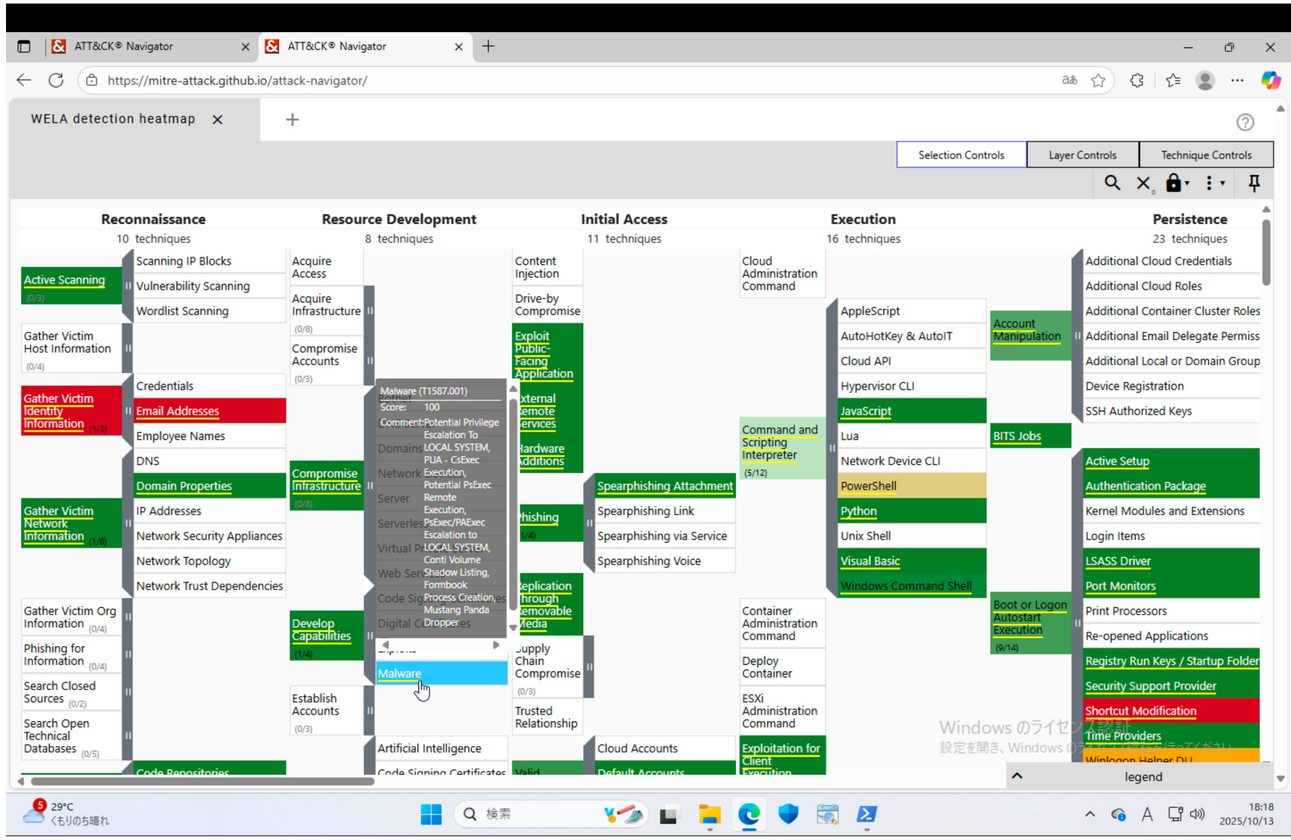
Log File	Current Size	Max Size	Default	Recommended	Is Full	Log Mode	Correct Setting
Application.evtx	2.07 MB	20 MB	20 MB	128 MB+	False	Circular	N
Microsoft-Windows-AppLocker%4EXE and DLL.evtx	0.07 MB	1 MB	1 MB	256 MB+	False	Circular	N
Microsoft-Windows-AppLocker%4MSI and Script.evtx	0.07 MB	1 MB	1 MB	256 MB+	False	Circular	N
Microsoft-Windows-AppLocker%4Packaged app-Deployment.evtx	1.00 MB	1 MB	1 MB	256 MB+	False	Circular	N
Microsoft-Windows-AppLocker%4Packaged app-Execution.evtx	0.07 MB	1 MB	1 MB	256 MB+	False	Circular	N
Microsoft-Windows-Bits-Client%4Analytic.evtx	0.00 MB	1 MB	1 MB	128 MB+	False	Circular	N
Microsoft-Windows-Bits-Client%4Operational.evtx	1.00 MB	1 MB	1 MB	128 MB+	False	Circular	N
Microsoft-Windows-CodeIntegrity%4Operational.evtx	0.07 MB	1 MB	1 MB	128 MB+	False	Circular	N
Microsoft-Windows-DriverFrameworks-UserMode%4Operational.evtx	0.00 MB	1 MB	1 MB	128 MB+	False	Circular	N
Microsoft-Windows-NTLM%4Operational.evtx	0.07 MB	1 MB	1 MB	128 MB+	False	Circular	N
Microsoft-Windows-PowerShell%4Operational.evtx	15.00 MB	15 MB	20 MB	256 MB+	True	Circular	N
Microsoft-Windows-PrintService%4Admin.evtx	0.07 MB	1 MB	1 MB	128 MB+	False	Circular	N
Microsoft-Windows-PrintService%4Operational.evtx	0.07 MB	1 MB	1 MB	128 MB+	False	Circular	N
Microsoft-Windows-Security-Mitigations%4KernelMode.evtx	1.00 MB	1 MB	1 MB	128 MB+	False	Circular	N
Microsoft-Windows-Security-Mitigations%4UserMode.evtx	0.07 MB	1 MB	1 MB	128 MB+	False	Circular	N
Microsoft-Windows-SmbClient%4Security.evtx	0.07 MB	8 MB	8 MB	128 MB+	False	Circular	N
Microsoft-Windows-TaskScheduler%4Operational.evtx	0.00 MB	10 MB	1 MB	128 MB+	False	Circular	N
Microsoft-Windows-TerminalServices-LocalSessionManager%4Operational.evtx	0.07 MB	1 MB	1 MB	128 MB+	False	Circular	N
Microsoft-Windows-Windows Defender%4Operational.evtx	0.07 MB	1 MB	16MB	128 MB+	False	Circular	N
Microsoft-Windows-Windows Firewall With Advanced Security%4Firewall.evtx	0.07 MB	1 MB	1 MB	256 MB+	False	Circular	N
Microsoft-Windows-WMI-Activity%4Operational.evtx	1.00 MB	1 MB	1 MB	128 MB+	False	Circular	N
Security.evtx	10.07 MB	20 MB	20 MB	256 MB+	False	Circular	N
System.evtx	2.07 MB	20 MB	20 MB	128 MB+	False	Circular	N
Windows PowerShell.evtx	1.07 MB	15 MB	15 MB	256 MB+	False	Circular	N

Audit file size result saved to: WELA-FileSize-Result.csv

MITRE ATT&CKの可視化



デフォルト設定



改善後

WELA - configure

```
Audit Policy: Object Access - SAM
[OK] Object Access - SAM

Audit Policy: Policy Change - Audit Policy Change
[OK] Policy Change - Audit Policy Change

Audit Policy: Policy Change - Authentication Policy Change
[OK] Policy Change - Authentication Policy Change

Audit Policy: Policy Change - Other Policy Change Events
[OK] Policy Change - Other Policy Change Events

Audit Policy: Privilege Use - Sensitive Privilege Use
[OK] Privilege Use - Sensitive Privilege Use

Audit Policy: System - Security State Change
[OK] System - Security State Change

Audit Policy: System - Security System Extension
[OK] System - Security System Extension

Audit Policy: System - System Integrity
[SKIPPED] System - System Integrity : Already set to Success and Failure.

Audit Policy: System - Other System Events
[SKIPPED] System - Other System Events : Already set to Success and Failure.

Configuration completed successfully
```

EventLog-Baseline-Guide

Comparison of Baseline Guides for Event Log Audit Settings

A security-driven approach to configuring Windows event logs

Windows Default

Windows Default Audit Settings

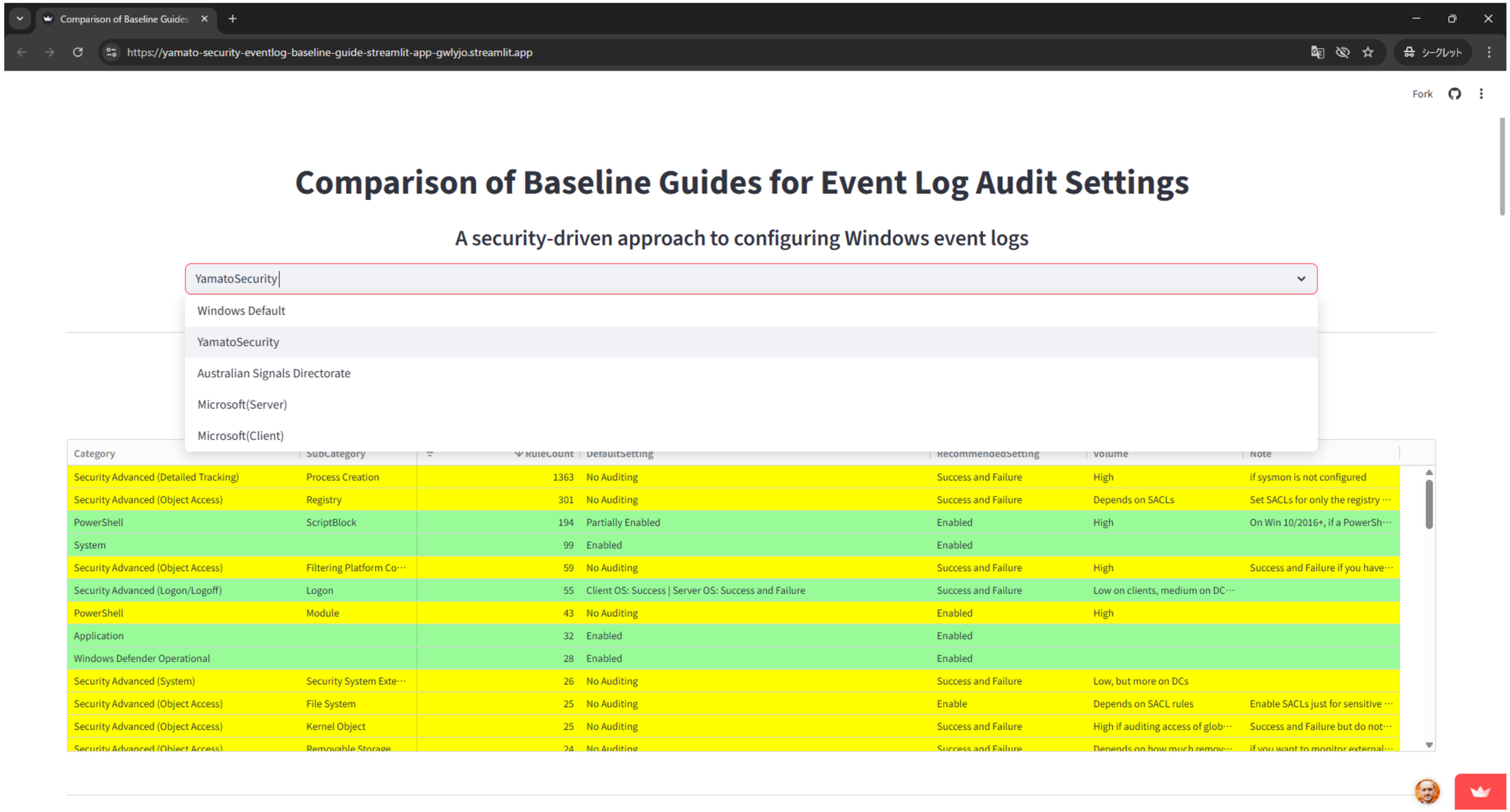
https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/plan/security-best-practices/audit-policy-recommendations

Category	SubCategory	RuleCount	DefaultSetting	RecommendedSetting	Volume	Note
Application		30	Enabled			
Applocker		1	Enabled			Enabled if AppLocker is enabled?
Bits-Client Operational		8	Enabled			
CodeIntegrity Operational		10	Enabled			
Diagnosis-Scripted Operational		1	Enabled			
DriverFrameworks-UserMode Operational		2	Enabled			
Firewall		9	Enabled			
Microsoft-Windows-NTLM/Operational		1	Enabled			This log is recommended to enable if you
PowerShell	Classic	21	Enabled			
PowerShell	Module	43	Disabled		High	
PowerShell	ScriptBlock	194	Disabled		High	On Win 10/2016+, if a PowerShell script i
PrintService	PrintService Admin	1	Enabled			
PrintService	PrintService Operational	1	Enabled			

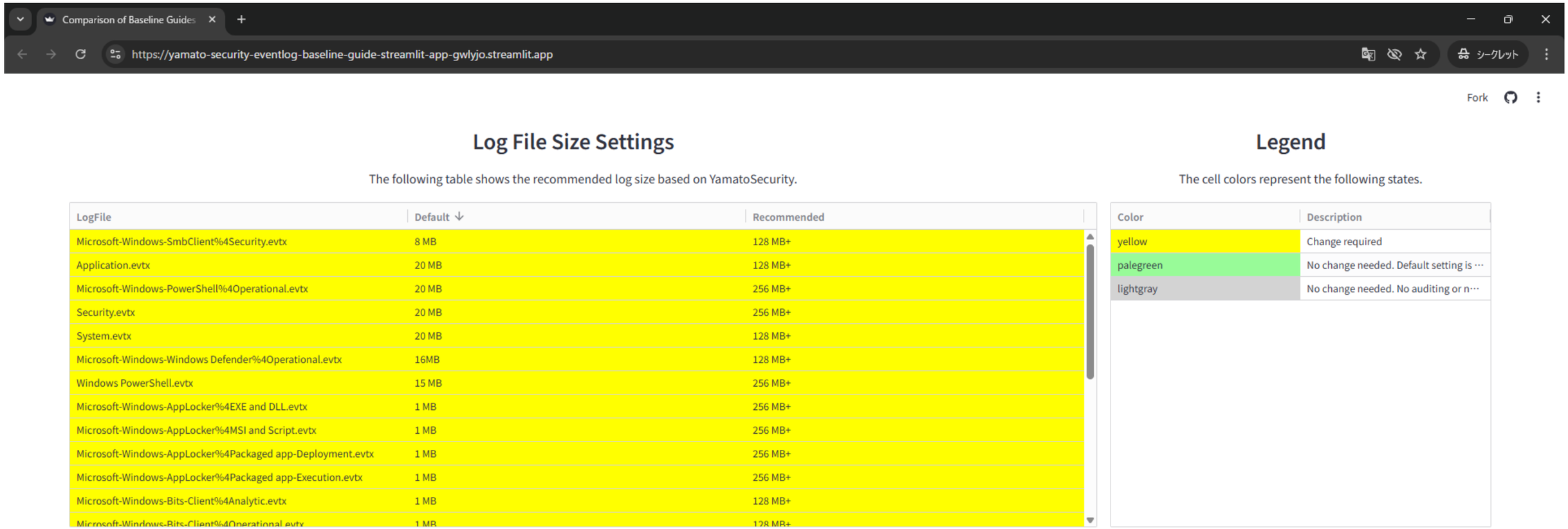
EventLog-Baseline-Guide

- https://github.com/Yamato-Security/EventLog-Baseline-Guide
- EventLog-Baseline-Guide
- リーダー: 田中ザック氏
- 開発者: 高橋福助
- 言語: Python, Streamlit
- Windows イベントログの監査設定を、複数のセキュリティベースライン間で比較・可視化
- Sigmaルールの検知カバレッジへの影響を分析できる Streamlit ツール

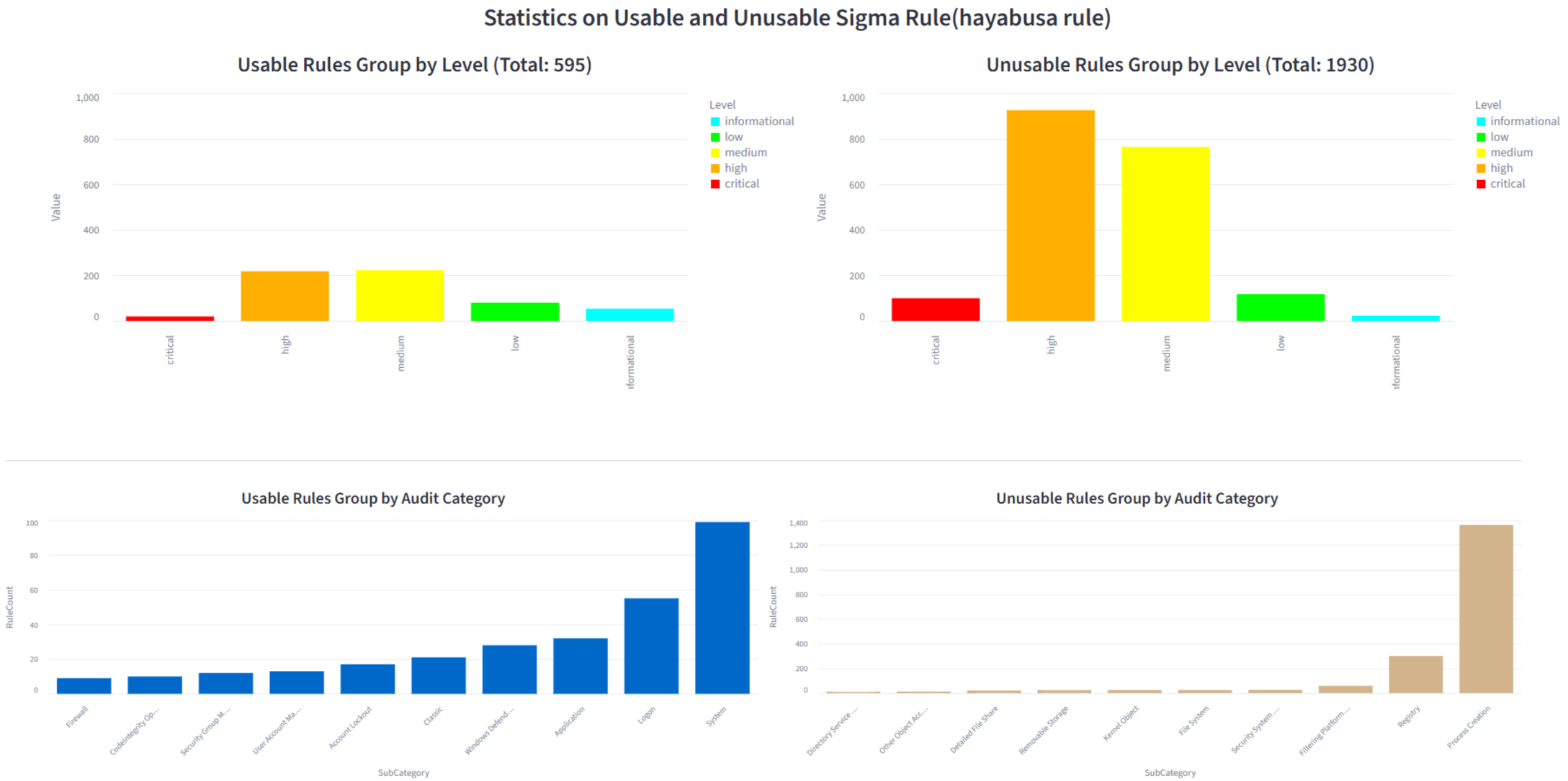
推奨ガイド設定前後の比較



デフォルト/推奨ファイルサイズ設定の比較



デフォルト/推奨設定で利用できるSigma



(おまけ)Hayabusa



(おまけ)log-metricsコマンド

Filename	Computers	Events	First Timestamp	Last Timestamp	Channels	Providers	Size
many-events-security.evtx	37L4247D28-05 IE10Win7 IE8Win7 IE9Win7	13,223	2013-10-24 01:16:13.765 +09:00	2016-09-21 00:46:32.738 +09:00	Sec	MS-Win-Eventlog Sec	10.1 MiB
many-events-system.evtx	37L4247D28-05 IE10Win7 IE8Win7 IE9Win7	8,414	2009-07-14 13:56:45.074 +09:00	2016-09-21 00:45:22.402 +09:00	Sys	BROWSER BTHUSB EventLog MS-Win-App-Exp MS-Win-DHCPv6-Cli MS-Win-DNS-Cli MS-Win-Dhcp-Cli MS-Win-DistributedCOM MS-Win-FilterMgr MS-Win-GrpPolicy MS-Win-HttpEvent MS-Win-Kern-General MS-Win-Kern-Processor-Pwr MS-Win-Kern-Pwr MS-Win-Pwr-Troubleshooter MS-Win-Setup MS-Win-Svc Pack Installer MS-Win-Time-Svc MS-Win-UserPnp MS-Win-WMPNSS-Svc MS-Win-Winlogon NetBT PNPMEM RDS-RCM SCM Tcpip USER32	4.1 MiB

デモ



Comparison of Baseline Guides for Event Log Audit Settings

A security-driven approach to configuring Windows event logs

Windows Default

Windows Default Audit Settings

https://learn.microsoft.com/en-us/windows-server/identity/ad-ds/plan/security-best-practices/audit-policy-recommendations

Category	SubCategory	RuleCount	DefaultSetting	RecommendedSetting	Volume	Note
Application		30	Enabled			
Applocker		1	Enabled			Enabled if AppLocker is enabled?
Bits-Client Operational		8	Enabled			
CodeIntegrity Operational		10	Enabled			
Diagnosis-Scripted Operational		1	Enabled			
DriverFrameworks-UserMode Operational		2	Enabled			
Firewall		9	Enabled			
Microsoft-Windows-NTLM/Operational		1	Enabled			This log is recommended to enable if you
PowerShell	Classic	21	Enabled			
PowerShell	Module	43	Disabled		High	
PowerShell	ScriptBlock	194	Disabled		High	On Win 10/2016+, if a PowerShell script i
PrintService	PrintService Admin	1	Enabled			
PrintService	PrintService Operational	1	Enabled			

